



סייבר ישראל

מערך הסייבר הלאומי

צמצום סיכוני סייבר עבור מערכות בקרה תעשייתיות (ICS)

הרחבה מקצועית



צמצום סיכוני סייבר עבור מערכות בקרה תעשייתיות (ICS)

הרחבה מקצועית

מסמך זה נועד לסייע לגורמי המקצוע ולגורמים טכניים בארגון, האמונים על זירת ה-OT בכלל ועל ה-ICS בפרט. המסמך לא נועד להחליף את הגורמים הנ"ל, אלא להוות כלי עזר לאיתור הסוגיות המרכזיות הכרוכות בסיכוני הגנת הסייבר בזירת ה-ICS. מסמך זה מבקש לייצר בנק בקרות מקצועיות, המבוססות על תקינה בינלאומית, על מחקרים ועל מסמכים מקצועיים, המפורטים במסמך, ומובן כי יישומן של בקרות מקצועיות בזירת ה-ICS בארגון ספציפי מצריך תהליך ייעודי של ניהול סיכונים והתאמת הבקרות לארגון על ידי בעלי תוכן ואנשי מקצוע מתאימים.



סייבר ישראל

מערך הסייבר הלאומי

כל הזכויות שמורות
למערך הסייבר הלאומי

06 1. מבוא

06	מבוא לסביבות ICS	1.1
08	מטרת המסמך	1.2
08	קהל היעד	1.3

09 2. סקירת רקע טכנולוגית של סביבות ICS (טופולוגיה ורכיבים עיקריים)

09	סקירת תת-מערכות ורכיבים מרכזיים בסביבת ICS	2.1
11	טופולוגיה קלאסית בסביבת ICS	2.2
11	מודל המשולש (מתאים בעיקר לסביבות פשוטות ולארגונים קטנים)	2.2.1
12	מודל PURDUE	2.2.2
14	תכנות ותקשורת בין בקרים ו-HMI	2.3
14	מגמות ואתגרים נפוצים בסביבות ICS	2.4

16 3. הצגת סיכוני סייבר על מערכות ICS

16	מבוא לסיכוני סייבר על סביבות ICS	3.1
19	אתגרי ההגנה בסביבות OT לעומת IT	3.2
20	התאמת מודל ה-CIA כמודל AIC לסביבה התפעולית	3.3
21	מודל הכוכב - מבוסס על NISTIR 8183	3.4
22	תמצית ההבדלים בין סביבת ה-IT לסביבת ה-OT	3.5
24	סיכוני סייבר על פי שכבות של מודל PURDUE	3.6

29 4. ערכה וניהול של סיכונים במערכות ICS ועקרונות למענה בתוכנית עבודה

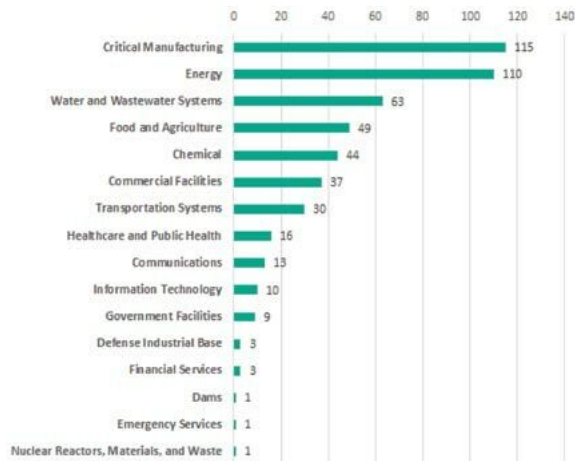
29	תהליך ניהול סיכוני סייבר כחלק מהערכה וניהול הסיכונים	4.1
30	מיפוי הסיכונים	4.2
32	ניהול סיכונים בסביבת ICS לעומת ניהול סיכונים בסביבת ה-IT	4.3

33 5. בקורות על מערכת ICS

33	בקרה להגנת סייבר במערכות ICS	5.1
----	------------------------------	-----

43 6. ביבליוגרפיה וחומר נלווה לקריאה

1.1 מבוא לסביבות ICS



מערכות **ICS = Industrial Control System** (בקרה תעשייתית) הוא מונח כללי עבור כמה סוגים של מערכות בקרה ושליטה, הנמצאות בשימוש בענפי התעשייה ובתשתיות קריטיות. מערכות אלו כוללות כמה תת-מערכות וקטגוריות. רשתות הבקרה נועדו כדי ליצור אוטומציה של פעילות תעשייתית (כדוגמת זיקוק נפט, סינון מים וכד') כמו גם אוטומציה בתהליכי קווי הייצור (כדוגמת תעשיית הרכב, פארמה וכד'). חלק ממערכות אלו מיועדות לנהל את הבקרה על רכיב בודד, כגון סנסור/מד גובה או טמפרטורה, המיועד לשליטה על פתיחה וסגירה של שסתום או שער. חלקן האחר מיועדות לשליטה על רכיבים מרובים, שנמצאים בפריסה מבוזרת בשטח.

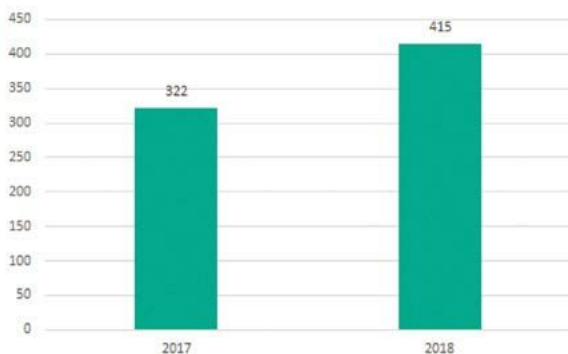
המכנה המשותף לכולן הוא, שמערכות אלו מיועדות לתקשורת עם רכיבי קצה, המשמשים כחיישן (סנסור) או כמפעיל (ביצוע פקודה/פעולה במרחב הפיזי).

סוגי מערכות ICS נפוצות:

- מערכות SCADA
- מערכות שליטה מבוזרות (DCS)
- מערכי בקרת מבנים (BMS)
- מערכות בקרה תעשייתיות לביצוע אוטומציה (IACS)

בשנים האחרונות גברה המודעות לאירועי סייבר, אשר התמקדו בתקיפת מערכות במרחב רשתות ה-ICS. בשונה מאירועים כנגד רשתות מחשוב וציוד מחשוב מסורתי, אירועים אלו עלולים בסבירות גבוהה להשליך ישירות על איכות חייהם ועל ביטחונם הפיזי של אזרחים. מעבר לפוטנציאל הפגיעה **בקו הייצור**, פגיעה במערכות מסוג זה עלולות להוביל להצפות של ערים, לדלף של גזים, רעלים או שפכים לסביבה, לפיצוץ של מכלים ולהשבתת שירותים חיוניים, כגון חשמל, גז, מים ועוד. מגמת התקיפה כנגד מערכות ICS נמצאת בעלייה בשנים האחרונות. הסיבה המרכזית לכך נובעת מאטרקטיביות התקיפה ומהקושי ליישם הגנה ובקורת אבטחה בסביבה התפעולית כמו אלו המיושמות ברשת ה-IT.

איור 1: פילוח חולשות ICS לפי סקטורים (מתוך אתר קספרסקי)¹



איור 2: מספר החולשות ב-ICS שהתגלו ב-2018 לעומת 2017 (מתוך אתר קספרסקי)²

https://ics-cert.kaspersky.com/media/KL_ICS_CERT_H2_2018_REPORT_EN.pdf 1

https://ics-cert.kaspersky.com/media/KL_ICS_CERT_H2_2018_REPORT_EN.pdf 2

עם האירועים הבולטים שהתפרסמו בשנים האחרונות אפשר למנות:

תקיפת TRICONEX

תקיפת המבוססת על סוס טרואני (סוסט"ר) ממשפחת TRITON אירעה בדצמבר 2017 וכוונה כנגד מערכת בטיחות תעשייתית. התוקף השיג נגישות לעמדת ההנדסה (Workstation Engineering) ולמערכת ה-SIS (Safety Instrumented System), ומשם השתמש בפלטפורמת התקיפה הנ"ל כדי לנסות ולשנות את אופן פעולתם ותכונותם של בקרי מערכת הבטיחות. מטרת התוקף הייתה לבצע פגיעה, שתביא לידי השבתה ונטרול של מערכת הבטיחות בתהליך הייצור⁴.

פריצה לסכר Bowman בארה"ב

ב-24 במרץ 2016 התפרסם, שהאקרים פרצו לסכר קטן במדינת ניו-יורק בארה"ב. התוקפים השיגו גישה למערכות השליטה, ובתוך כך נחשפו לנתונים על אודות המפלס, הטמפרטורה ונתונים רגישים נוספים אחרים. השתלטות זדונית זו עלולה הייתה להוביל להצפת עיר, לפגיעה במערכות קריטיות ולפגיעה כספית משמעותית לעיר.

BlackEnergy - השבתת תחנות כוח באירופה

ב-23 בדצמבר 2015 אירעו בחברות חשמל באירופה מקרי הפסקת חשמל, שהשביתו אזורים שלמים. נמצא, כי התוקף שתל פוגען במסמך אקסל של מיקרוסופט ושלה אותו באמצעות מייל ממוקד (Spear Phishing). יכולת השיטוי והדילוג ממערכות ה-IT למערכות ה-OT הובילו להרצת Blackenergy בארגון. באירוע זה ניצל התוקף את היכולת לדלג ממערכות ה-IT למערכות ה-OT⁵.

3 https://ics.sans.org/media/SANSICS_DUC4_Analysis_of_Attacks_on_US_Infrastructure_V1.1.pdf - אירועים נוספים.

4 <https://www.gov.il/BlobFolder/reports/sis/he/SIS-CERT-IL-W-400.pdf>

5 <https://www.us-cert.gov/ics/alerts/IR-ALERT-H-16-056-01>

- **אנשי אבטחת רשתות במערכות ICS** - מכורח מעורבותם ליישום בקרות/אמצעים להגנת הסייבר, אחראי מערכות אבטחה
- **נאמני ביטחון ICS** - כחלק מתחום אחריותם (לרוב מינוי על ידי ה-CISO או גורם ניהולי)
- **חברות אינטגרציה, חברות ייעוץ ונותני שירות בתחום ה-ICS**
- **אנשי IT** - הפועלים או תומכים במערכות מחושב בסביבות ייצור



איור 3: מפעיל בקו ייצור

1.2 מטרת המסמך

מסמך זה נועד להקנות לקהל המקצועי את הידע הבסיסי הנדרש לטובת הגנה טובה יותר על מערכות ICS. המסמך יוצק ידע לצד שיטות ותהליכי עבודה להעלאת החוסן בפס הייצור. בתוך כך, הוא כולל דוגמאות וסיכונים מייצגים, דרכי התגוננות, המלצות ובקורות להפחתת סיכונים בסביבה התפעולית. המסמך מהווה הרחבה מקצועית בזירת ה-ICS למסמך "תורת ההגנה בסייבר לארגון".

1.3 קהל היעד

מסמך זה רלוונטי לעוסקים בתחום ההגנה על מערכות בקרה תעשייתיות לרבות ה-CISO, לאנשי ההגנה בסייבר בארגון ולאנשי התפעול והבקרה, ובחלקים מסוימים מכוון גם לגורמים נוספים בארגון, כדוגמת מנהלי סיכונים ואנשי רכש, האמונים על נושאי הצטיידות מחשוב גם לסביבת ה-OT. קהל היעד למסמך זה כולל את הגורמים האלה:

- **מהנדסי/טכנאי ICS** - האמונים על תהליכי התקנה ותחזוקת מערכות ICS
- **מפעילי ICS** - המעורבים בתהליכי תפעול שוטף ומתמשך של המערכות

««« 2. סקירת רקע טכנולוגית של סביבות ICS (טופולוגיה ורכיבים עיקריים)

2.1 תת מערכות פרוטוקולים ורכיבים מרכזיים בסביבת ICS:

SCADA (Supervisory Control and Data Acquisition) -

מערכת מבוססת תקשורת, המאפשרת שליטה, בקרה ופיקוח על תהליכים. זאת, באמצעות שליחת פקודות ייעודיות לבקרים. תהליכים אלו לרוב הינם תהליכי הפקה, ייצור, זיקוק, יצירת אנרגיה והרכבת מוצרים. המערכות כוללות שכבה ממוחשבת לניטור ושליטה על האביזרים. תהליכים בתעשייה כוללים, בין השאר, תהליכי הפקה, ייצור, זיקוק, יצירת אנרגיה והרכבת מוצרים.

תהליכים בתשתיות ציבוריות או פרטיות כוללים, בין השאר, מערכות תאורת חוץ (עירוניות ובין-עירוניות), מערכות לאספקת מים, לאיסוף וטיהור שפכים, לניטור צנרת להולכת נפט וגז, רשת החשמל, מערכת צופרי אזעקה ומערכות תקשורת גדולות.

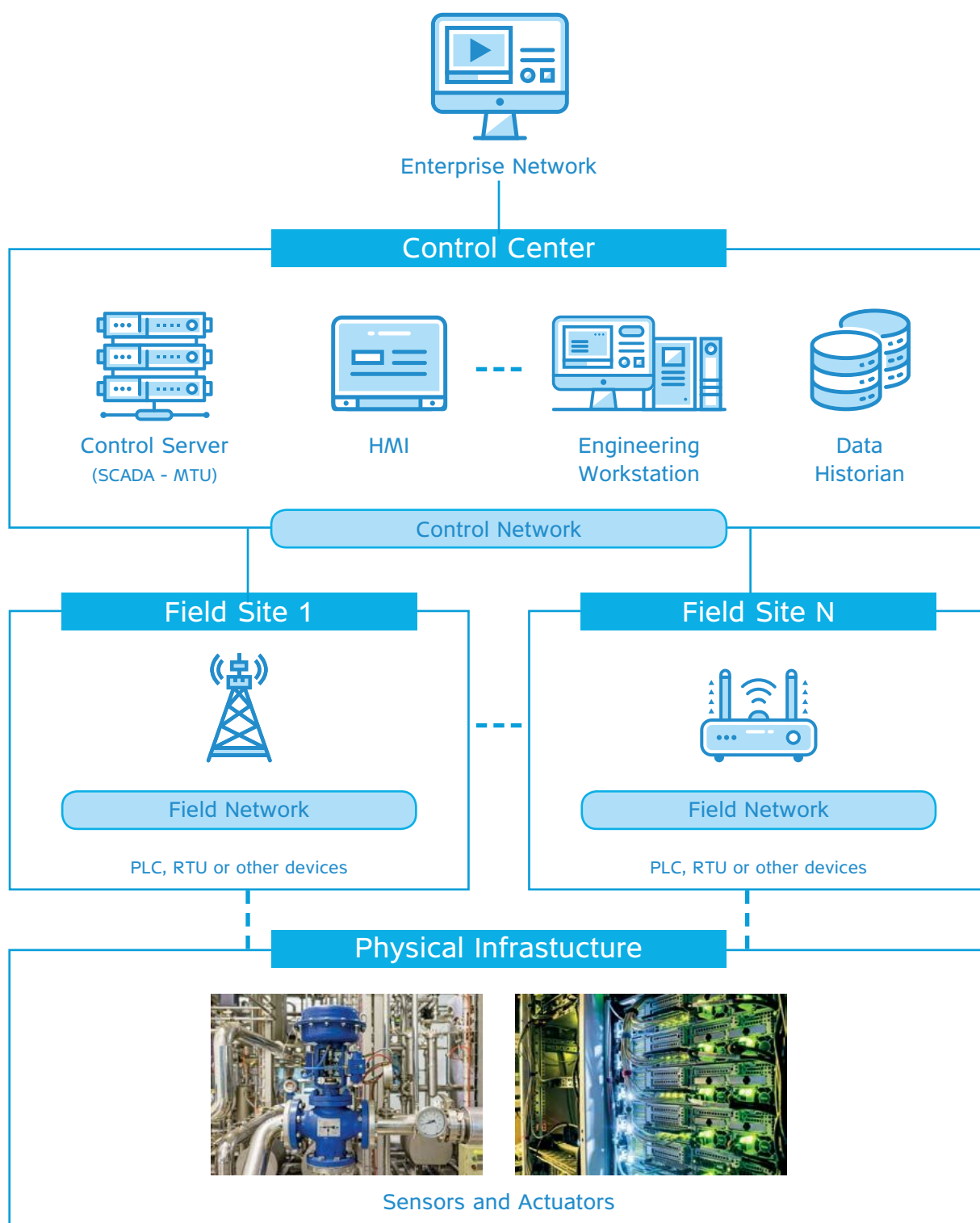
תהליכים במתקנים ציבוריים או פרטיים, כולל ניהול מערכות בניינים, שדות תעופה, נמלים, אוניות ותחנות חלל. מערכות SCADA מנטרות ושולטות על מערכות HVAC (Heating, Ventilation, and Air Conditioning), חימום, אוורור ומיזוג אוויר, הפועלות במתקן.

פרוטוקולים של רשתות תעשייתיות - פרוטוקולים של רשתות תעשייתיות הם פרוטוקולים של תקשורת בזמן אמת שפותחו בכדי לקשר בין מערכות, ממשיקים, והתקנים שיחד מהווים מערכת בקרה תעשייתית. רובם תוכננו בתחילה לתקשורת טורית על חיבורים טוריים אבל בהמשך הזמן הותאמו לעבודה על רשתות Ethernet תוך שימוש בפרוטוקול תקשורת כדוגמת TCP/IP. נקודות החולשה של רשתות תעשייתיות ידועות ברובן ונובעות ממחסור במודעות, ידע, חולשות בקונפיגורציה של המערכת, חולשות תוכנה, מחסור בהגנה מפני פוגענים, בעיות הצפנה ועוד.

מערכת SCADA כוללת על פי רוב את הרכיבים האלה:

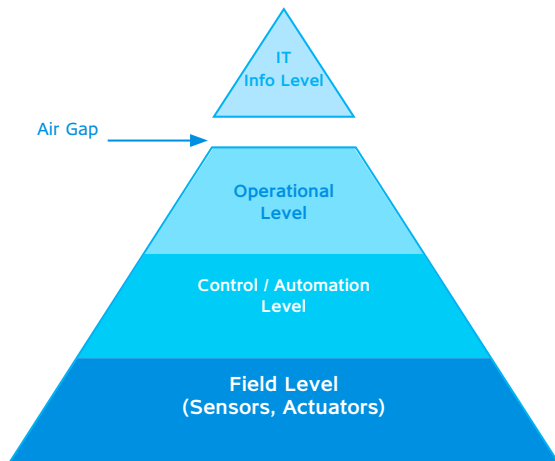
- **HMI (Human-Machine Interface) -** ממשק אדם-מכונה, המציג מידע על התהליך למפעיל, וכך מאפשר למפעיל לנטר ולבקר את התהליך.
- **MTU (Master Terminal Unit) -** מערכת פיקוח מרכזית, שנועדה לנטר, לפקח ולהפעיל את רכיבי הקצה.

- **PLC (Programmable Logic Controllers) -** בקרים לוגיים, המתוכננים לקבל קלט, להפעיל לוגיקה (שנטענת מראש) ועל סמך הלוגיקה להעביר פקודות לאביזרים.
- **RTU (Remote Terminal Unit) -** יחידות ניטור ממוחשבות, המעורבות בתהליך ובתוך כך מחוברות לחיישנים הממוקמים באתר התהליך.
- **Historian -** מערכת האוגרת לאורך זמן את נתוני האביזרים מהשטח ומציגה מגמות בשינוי הפרמטרים הנמדדים בתהליך. המערכת בדרך כלל משמשת את מהנדסי הבקרה לשיפור ולכוונון התהליך.
- **Sensors -** חיישנים המודדים תנאים פיזיים ובעלי יכולת הפעלת Actuators ושידור למערכות הבקרה.
- **Actuators -** מופעלים על ידי החיישנים ומפעילים את השינוי הנדרש (כגון פתיחת שסתום).
- **תשתית תקשורת -** מקשרת את מערכת הפיקוח ליחידות (תקשורת: קווית, רדיו, סלולר, Wi-Fi, לוויין).
- **IED (Intelligent Electronic Device) -** התקנים אלו מהווים חלק ממערכות הבקרה כגון חיישנים, מנועים, שנאים, משאבות וכד'. גם מצוידים במעבד זעיר שמאפשר דיווח. התקנים אלו מתקשרים בדרך כלל באמצעות פרוטוקול fieldbus ומתפקדים כ-Slaves ומבוקרים באמצעות יחידות קצה מרוחקות.
- **IOT (Internet of Things) -** רכיבים ייעודיים, המבוססים תקשורת ויכולת להחלפת מידע באמצעות האינטרנט.
- **IIOT (Industrial Internet of Things) -** רכיבים ייעודיים לתעשיית הייצור, המבוססים תקשורת ויכולת להחלפת מידע באמצעות האינטרנט.



איור 4: תיאור רכיבים בסביבת ICS

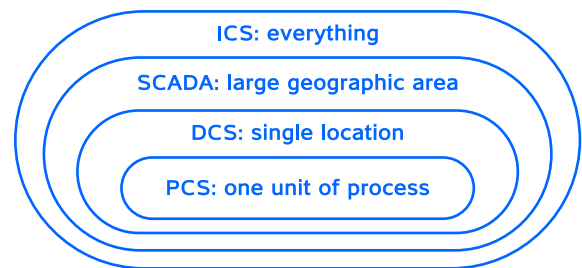
2.2.1 מודל המשולש (מתאים בעיקר לסביבות פשוטות ולארגונים קטנים):



איור 6: מודל המשולש

- הפרדת המשולש לאחר תשומות בידול ה-IT:
- **סביבה עסקית ומערכת IO בארגון.** רשת זו מסועפת ומקושרת לעתים ישירות לאינטרנט.
- **סביבת ניהול ברשת הייצור** (מבודלת).
- **שרתי השליטה והבקרה והבקרים עצמם, שמהווים את לב המערכת -** אזור שבו מריצים תהליכים לכל ההתקנים המקומיים והמרוחקים.
- **ב-2 השכבות הנמוכות ביותר במודל מופיעים הבקרים התעשייתיים** מסוגי PLC, RIO, IED. זאת, בהתאם למבנה המערכת. רכיבים אלה מחוברים אל חיישנים (SENSORS) ואמצעי הפעלה באמצעות ממסרים שמפקחים על תהליך הייצור (ACTUATORS).

DCS (Distributed Control System) - מערך זה מבדיל את ה-DCS ממערכות לא מבוזרות, שמשמשות בבקרי יחיד במיקום מרכזי. מערכת ה-DCS משתמשת בצורה אופיינית במעבדים (processors) מותאמים למשימה, שמאורגנים בהיררכיה ומקושרים על ידי רשתות תקשורת לצורך ניטור ובקרה.



איור 5: תת-המערכות המרכזיות בעולם ה-ICS

2.2 טופולוגיה קלאסית בסביבת ICS

סביבת ה-ICS הינה סביבה מורכבת. הסביבה משלבת סביבת ניהול, המקושרת לעתים למערכות ERP ודומיה, סביבת תפעול, עמדות מחשבים, חיישנים ובקרים (ראו סביבת קלאסית באיור 4). קיימים שני מודלים, שיכולים לסייע בשלבי התכנון והיישום של הארכיטקטורה בסביבת ה-ICS:

- **מודל המשולש (מבוסס על ISA 95)**
- **מודל PURDUE**

מודלים אלו מאפשרים התייחסות מבנית לפי היררכיה ושכבות רשת מערכות הבקרה. התיאור המערכתי המובא באמצעות חמש הרמות במשולש הוא פשטני יותר ומתאים למערכות לא מורכבות. מודל PURDUE כולל חלוקה לשש רמות ומתאים לארגונים גדולים/סביבות מורכבות יותר. ככלל, שני המודלים מפרידים את תחום ה-IT - המנהל את המערך העסקי של הארגון - מן ה-OT והתחום שבו גם מנוהלים רכיבים פיזיים, המקבלים הוראות באמצעות פקודות של שינוי בזרם החשמל.

6 הפרדת ה-Airgap נכונה, והיא נהוגה בעיקר בתשתיות קריטיות. קיימים ארגונים שבהם ההפרדה בין הסביבות מתבססת על FW, Vlan, ייעודי וכד'.

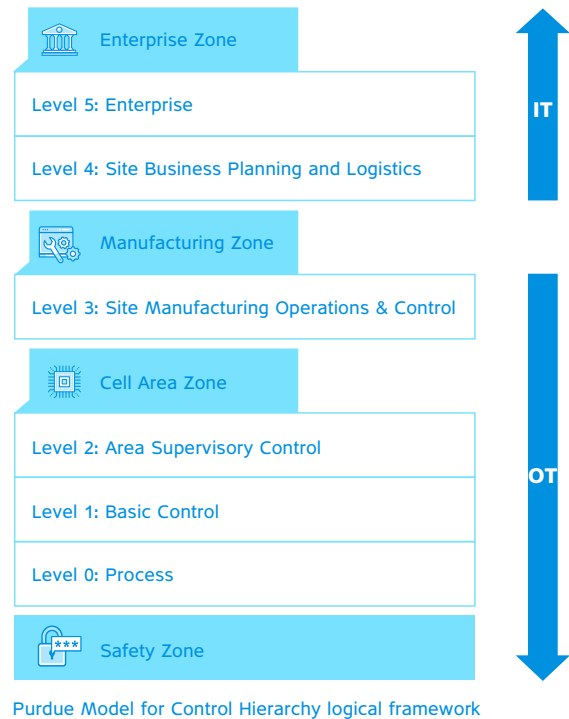
באמצעות התקני חומת אש (Firewall), או כאלו שבהם התקשורת הינה חד-כיוונית ומופרדת באמצעות התקן ליצירת תעבורה חד-כיוונית דיודה (DIODA).

• **רמה 2 - בסביבה זו קיימות מערכת השליטה בממשק HMI, ותפקידה לאפשר צפייה ובקרה של תהליכי שו"ב וגם לאפשר התערבות של מפעיל על פי הצורך ועל פי ההרשאות שיש לו. ברמה עקרונית מגבילים את ההרשאות של המפעיל לפעולות שאין בהן סיכון לגרימת נזק (כדוגמת פעילות זדונית לתכנות או לשינוי פקודות בקר). במערכות מורכבות יש כמה עמדות של מפעילים (HMI), מה שמאפשר למפעילים להתמקד באזורים שונים של המערכת, או לבצע התערבות על פי הצורך.**

• **רמה 1 - בסביבה זו מתנהלים תהליכים באמצעות מחשבי בקרה (Automation Server) לגבי כל ההתקנים שפועלים באמצעות בקרים מסוג RTU, PLC וכו'.**

• **רמה 0 - מייצגת את השכבה הנמוכה ביותר במודל ה-PURDUE, ומופיעים בה בקרים תעשייתיים מהסוגים RTU, PLC, RIO - על פי מבנה המערכת. אלה מחוברים אל החיישנים (Sensors) ואל אמצעי ההפעלה (Actuators), שמפעילים את המכונה.**

2.2.2 מודל PURDUE



איור 7: חלוקת המודל לפי אזורים

מודל זה מציג תיאור מורחב ביחס למודל המשולש ומכיל שש רמות (0-5). מבנה זה מתאים לארגונים בינוניים וגדולים, שקיים בהם ממשק לרשת ה-IT.

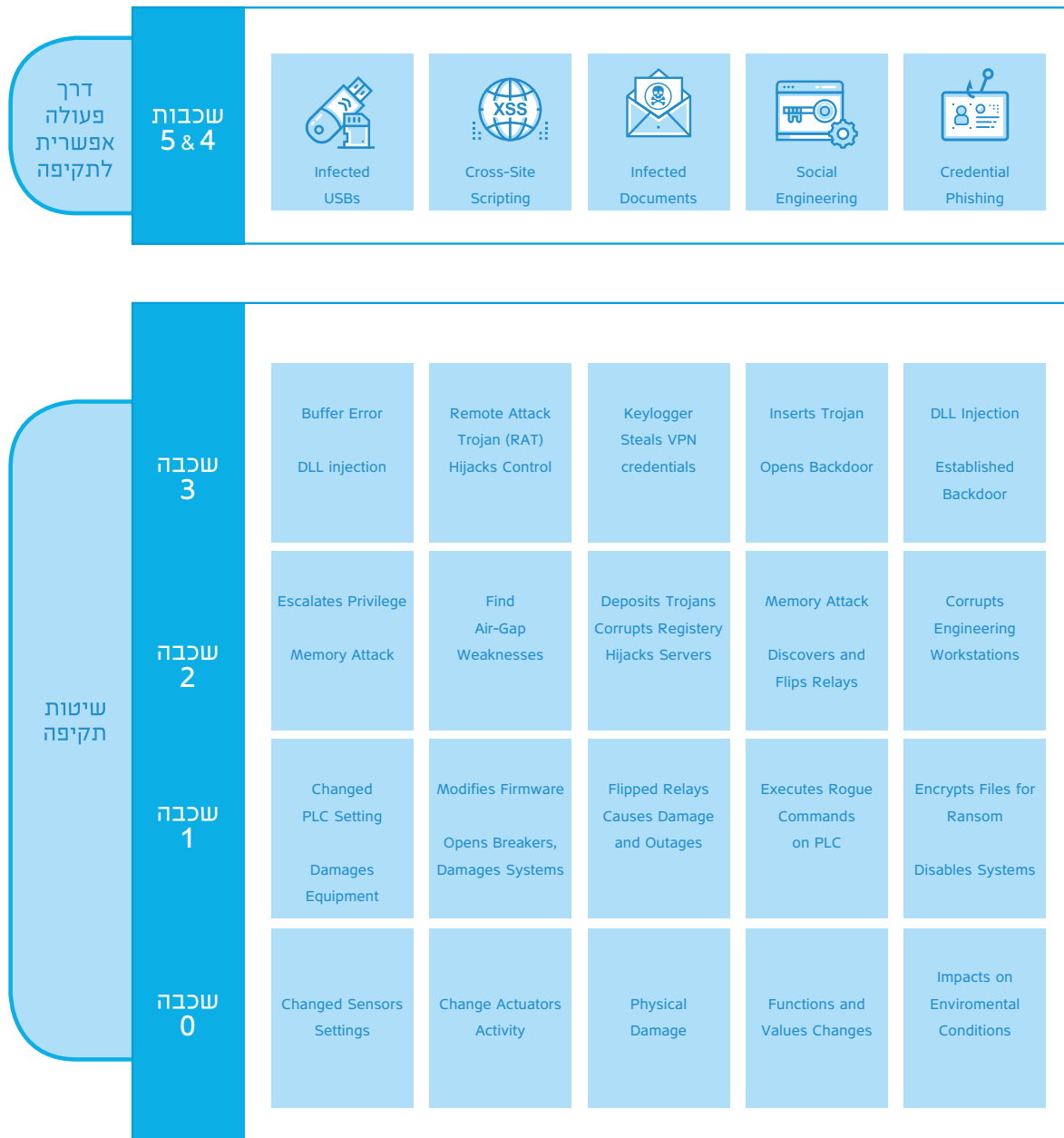
• **רמות 5 ו-4 -** אזור זה הינו אזור ייעודי לסביבת ניהול תהליכים עסקיים, וככזה, הוא מבוסס על מערכות ושירותי ה-IT של הארגון (Enterprise). ברמה זו מופיע החיבור לשירות האינטרנט של הארגון, מערכות ERP וכד'.

• **רמה 3 -** באזור זה נכללים סביבת ניהול ברשת הייצור, חומרים, כוח אדם, מלאים, זמינות של מכונות (כדוגמת מערכות ה-MES וכד'). ישנן מערכות ארגוניות, שבהן הקישור בין רמה 3 למערכת שו"ב (רמה 2) מתבצע

7 <https://www.encompass-inc.com/top-10-automation-trends-in-2018>

8 https://www.gov.il/BlobFolder/policy/protection_of_erp_systems/he/Protection%20of%20EPR%20systems_576699_4_WEB.pdf

מיפוי התקיפות האפשריות בהתאם למודל PURDUE:



איור 8: דפ"א התקפות לפי שכבות

2.3 תכנות ותקשורת בין בקרים ו-HMI

פסקה זו מתארת את תהליך הרקע בתכנות בקרים במטרה להבין את ההזדמנויות בראיית התוקף והסיכונים בתהליך טעינת הבקרים (והיכולת לתכנות). במהלך השנים פותחו בקרי PLC על ידי יצרנים שונים, כולם פיתחו מוצר ייחודי בעל ממשק משתמש ופונקציות ייחודיות. עם השנים, החלו תכנות בשפות שונות, סביבות וצרכים משתנים - מה שהוביל לקושי תפעולי ואבטחתי גובר בתקשורת בין בקרים מתוכנתים מתוצרת יצרנים שונים.

סביבת בקרים מעורבים: על אף הצורך והמלצת היצרן להשתמש בבקרים אחידים (מאותו יצרן וגם מאותה משפחה של מוצרים), ישנן גם סביבות מעורבות, שמשולבים בהן כמה בקרים המיוצרים על ידי חברות שונות. כדי לאפשר גמישות בבחירת בקרים, קיימות אפשרויות לתכנות הבקרים באמצעות כלי תכנות סטנדרטיים ושיטות תכנות כפי שמתואר בתקן IEC 61131-3. בגרסת התקן, שהתפרסמה בשנת 2013, הוגדרו חמש שפות תכנות. לכל משפחה של בקרים המיוצרים בחברה מסוימת יש ממשק גרפי ייחודי, ש"מקמפל" את קובץ הקונפיגורציה בצורה ייחודית רק לאותו סוג בקר (מאותה החברה). בסביבה מעורבת, מהנדסי בקרה נדרשים להיכרות עם כמה תוכנות גרפיות.

במערכות חדשות, תכנות הבקרים מבוצע באחת מחמש השפות שמוגדרות בתקן ה"ל", דבר שמאפשר את העברה של היישום ושילוב "בקלות יחסית" בעבודה עם בקרים של יצרנים שונים.

תכנות בקרים: בעבר נהוג היה לתכנת את הבקרים באמצעות שיטה יחידה בשם Ladder Diagram, ואת מחשבי הבקרה (HMI) - באמצעות תוכנה של ספק HMI. תהליך זה מתבצע על ידי מחשב הנדסה (Engineering Station).

שפות התכנות הנפוצות ביותר:

• שפת דיאגרמת סולם (Ladder Diagram)

שיטה קלאסית, שמאפשרת למתכנת לתרגם את תהליך החשיבה הלוגית לשרטוט ודיאגרמה. תהליך התכנות, מתבצע באמצעות תרגום תהליך עסקי רצוי לרצף פעולות המיוצגות באמצעות איורים מתחום החשמל המדמים מתג, כניסה דיגיטלית, מונה זמן ועוד..

• פונקציה אחודה (Function Blocks)

הפונקציה מאפשרת להשתמש ברכיב תוכנתי אחד בכמה מקומות שונים, תוך שמירה על אחידות הפעולות וייעול כתיבת התוכנה.

הערה: חשוב לציין, כי בקרים שפותחו תוך שימוש באמצעים אלה חסינים יותר בפני ביצוע שינויים בתהליך התוכנה באופן שיפגע התהליך.

• שפות נוספות

שפת Instruction List (IL), שפת Structure Text (ST), שפת Sequential Function Chart (SFC).

2.4 מגמות ואתגרים נפוצים בסביבות ICS

סביבת ייצור

- **סטנדרטיזציה -** שימוש במערכות הפעלה סטנדרטיות, הכוללות חולשות הניתנות לניצול בהיבטי סייבר.
- **הצורך בחיבוריות וקישוריות -** קישור בין רשתות או קישור לרשתות ה-IT והאינטרנט מגביר את החשיפה ואת שטח התקיפה.
- **קישוריות לא מאובטחת -** שימוש במודמים, בגישות תחזוקה מרחוק, שימוש בתקשורת אלחוטית (כגון Wi-Fi).
- **אבטחת מידע וארכיטקטורה -** זמינות מידע על ארכיטקטורה, נוהלי התקנה ותחזוקה, מבנה תצורת הקישוריות עם הבקרים, חולשות על בקרים ומפגעי סייבר מפורסמים וידועים בכל רחבי האינטרנט.
- **שימוש ברכיבי IoT.**

שכבת האפליקציה

- אפליקציות מיושנות, אשר נכתבו בצורה שאינה מאובטחת.
- האפליקציות אופיינו לסביבת ייצור תוך תשומות לרצף פרודקטיביות, זמינות וביצועים ולא דווקא כנגד איומי סייבר.

שכבת קונפיגורציה

- המערכות נבנו לעבוד שנים ברצף, ללא ביצוע אתחולים, כך שקשה מאוד ליישם בהן עדכונים.
- פעמים רבות הסיסמאות צרובות בקוד (Factory Default Passwords) ולעיתים קשה לשנותן.

- החשש והסיכון לעכב תהליכי ייצור (כגון Ping Sweep, שגרם לתקלות בעבר).
- קושי תפעולי ומשפטי לבצע מבדקי חדירות קלאסיות ואקטיביות ברשת ובציוד מחשש להפלת המערכת.
- קושי בביצוע הצפנה וסגמנטציה רשתית.

- לרוב קיים קושי בהצפנת שדות (רגישים).
- לא תמיד ניתן להתקין מערכות אנטי-וירוס בציוד (מסיבות תפעוליות וחוזיות), או מערכות למניעת הרצת קוד לא מוכר.
- קושי בניהול והזדהות משתמשים, שכן מדובר בסביבת תפעול.

שכבת רשת

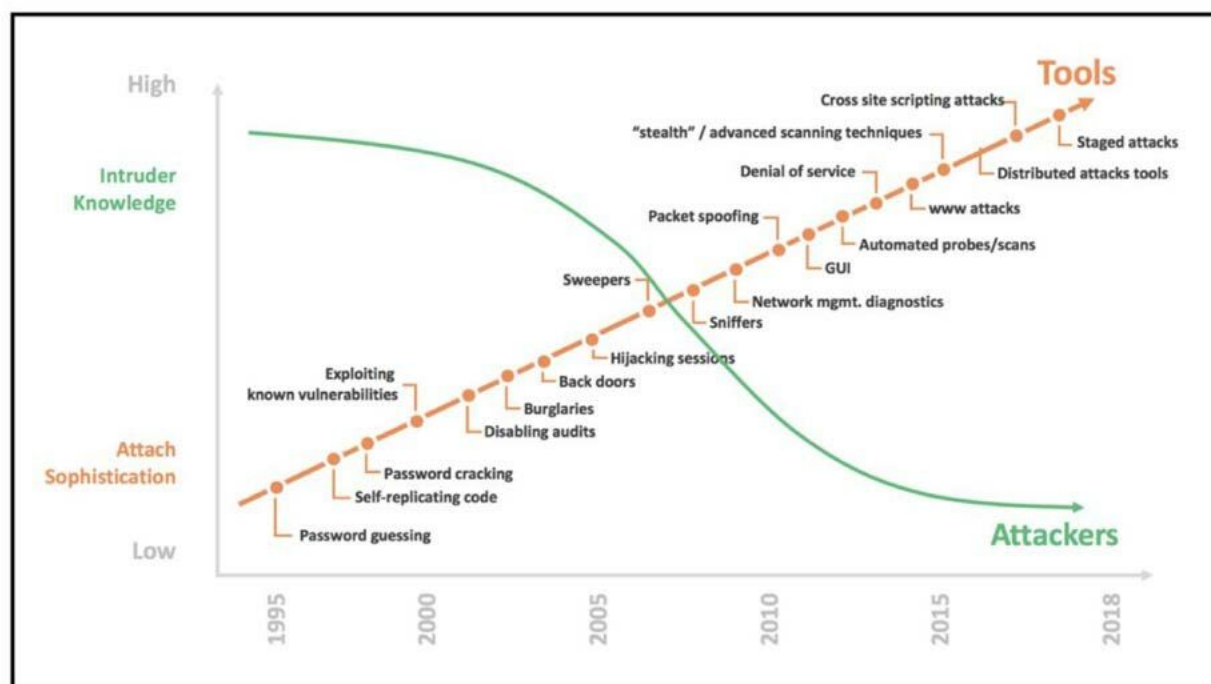
- התפתחות הטכנולוגיה הובילה למגמה של קישור בין רשתות תפעוליות מבודדות לסביבה מינהלתית, ובכך יצרה פגיעויות רבות, החושפות אותן למגוון רחב של איומים.
- התמקדות בביצועי Real time מונעת הכנסת רכיבי אבטחת מידע רשתיים (Latency).
- קושי לבצע סריקת רשתות (Asset Management) בשל

3. הצגת סיכוני סייבר על מערכות ICS

3.1 מבוא לסיכוני סייבר על סביבות ICS

ניתוח היסטוריית אירועי ICS שהתפרסמו מעלה, כי האיומים על סביבות אלו אינם שונים מהותית מהאיומים על סביבות IT. בשני המקרים ניתן לסווג את האיומים לכאלו אשר מעוניינים לפגוע באמינות/מהימנות, זמינות וסודיות הנתונים (CIA). איומים אלו כוללים ניסיונות לפגוע ברציפות העסקית באמצעות מתקפת DDOS, האזנה לתקשורת, שיבוש ו/או שינוי תפקודו של רכיב במערכת, גניבת נתונים, התקפות כופר ועוד. לעתים תקיפת רשת הייצור מתחילה בתקיפה מקדימה על רשתות ה-IT (כדוגמת אירוע תקיפת תשתית אנרגיה באוקראינה - BLACKENERGY).⁹ הסיכון הגדול בתקיפות ICS הוא בהוצאת תהליך מאיזון ופגיעה מהותית בציוד, כגון דוד, טורבינה וכד', דבר שיכול לגרום נזק משמעותי באספקת שירות חיוני או לפגיעה בחיי אדם.

כמערכות תפעוליות וקו ייצור, מערכות ה-ICS הינן מערכות המתוכננות ונמצאות בשימוש לאורך שנים. לעתים מדובר ברשתות ללא בקורות או מנגנוני אבטחה (פיזיים או לוגיים) וללא תשומות כנגד התקפות סייבר. בשנים האחרונות יכולות המימוש של תקיפות על מערכות ICS הפכו לקלות עוד יותר. המגמה נובעת, בין היתר, מהיכולת לאתר חולשות, לזהות פרצות, להשיג ולהשמיש כלי פריצה, ואלה הובילו לעלייה במגמת התקיפה. שימוש בכלים וביכולות קיימות, כדוגמת שימוש באתר SHODAN, מאפשרים לבצע מיפוי של סביבות ICS המקושרות לאינטרנט.



איור 9: התפתחות כלי התקיפה לסביבות ה-ICS בשנים האחרונות¹⁰

⁹ <https://www.nozominetworks.com/downloads/US/Nozomi-Networks-TRITON-The-First-SIS-Cyberattack.pdf>

¹⁰ <https://www.nozominetworks.com/downloads/US/Nozomi-Networks-TRITON-The-First-SIS-Cyberattack.pdf>

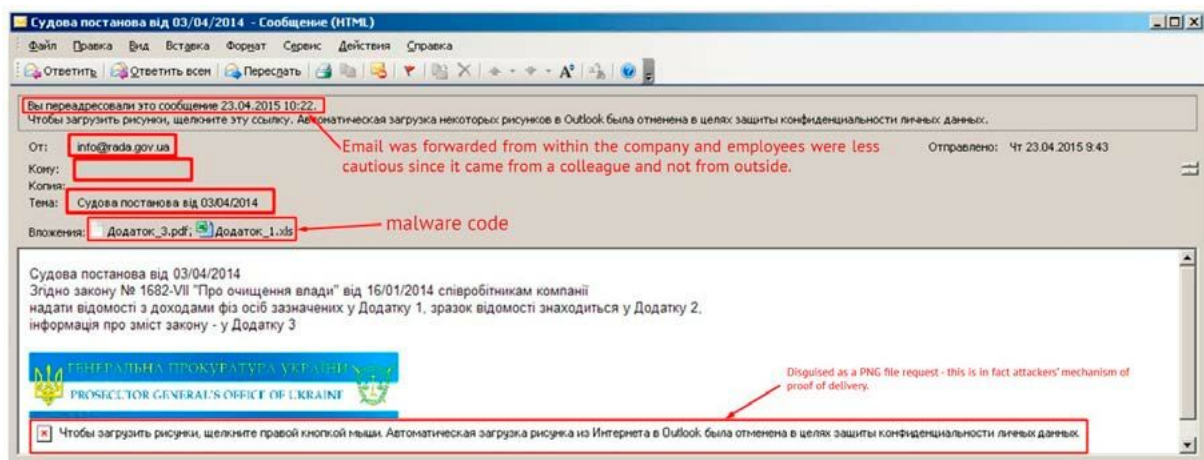
¹¹ <https://www.us-cert.gov/ncas/alerts/TA18-074A#revisions>

שיטות התקיפה הפופולאריות לרשתות ICS נשענות, בין היתר, על:

- ניצול מנגנוני הזדהות חלשה (Weak authentication)
- סריקת פורטים (Network scanning/probing) - כחלק מתהליך התקיפה לאתר פורטים פתוחים בשלב ההתארגנות ואיסוף המידע
- מצעים אוגרי מידע (Removable media) - כחלק מתהליך דילוג, הדבקה והתפשטות
- הפעלת כלים ותוכנות לפריצת סיסמאות (Brute force) - כחלק מתהליך ניסיון פריצה
- ניצול הרשאות לגטימיות (Abuse of access authority) - על ידי המשתמש עצמו או פוגען המתוכנת לנצל את ההרשאות
- תהליכי תקיפה המתחילים מהתקפות דיוג (Phishing & Spear phishing) - פופלארי בעיקר לרשתות ICS המקושרות לאינטרנט (כדוגמת אירוע BLACKENERGY ותקיפת תשתית קריטיות)¹³
- הזרקת שאילתות SQL

תרחישים לדוגמה:

- ניצול סיסמאות ברירות מחדל
- שינוי פקודה של בקר
- תקיפות מבוססות GPS או תקשורת לוויינית
- האזנה לתקשורת
- החדרת קוד עיון באמצעות שדרוג
- החדרת קוד עיון באמצעות חיבור התקן חיצוני



איור 10: תקיפה שהחלה במרחב ה-IT לצורך מימוש כוונות ב-OT¹⁴

¹² https://www.us-cert.gov/sites/default/files/recommended_practices/NCCIC_ICS-CERT_Defense_in_Depth_2016_S508C.pdf

¹³ <https://www.us-cert.gov/ncas/alerts/TA18-074A#revisions>

¹⁴ <https://socprime.com/en/blog/dismantling-blackenergy-part-3-all-aboard>

בדירוג של עשרת האיומים בנושא זה לשנת 2019, שפורסם על ידי ארגון ה-BSI הגרמני, עולה התמונה הבאה:

Top 10 Threats	Trend since 2016
Infiltration of Malware via Removable Media and External Hardware	↗
Malware Infection via Internet and intranet	↗
Human Error and Sabotage	↑
Compromising of Extranet and Cloud Components	↑
Social Engineering and Phishing	↘
(D)Dos Attacks	↑
Control Components Connected to the Internet	→
Intrusion via Remote Access	→
Technical Malfunctions and Force Majeure	↘
Compromising of Smartphones in the Production Environment	→

איור 11: שינויים במגמות תקיפה בשנת 2019 ביחס לשנת 2016¹⁵

בשנים האחרונות גדל כוח המחשוב וגבר הצורך לקישוריות מגוונת עם מערכות נוספות, כגון ניתוח וחיזוי עסקי, ניתוח ביצועי תפעול, מדידת תפוקות, חיזוי כשלים, פתרון תקלות וכד'. יכולות אלו נועדו למנף פעילות ארגונית ולספק צורך עסקי ופונקציונליות בהווה וצורך עתידי. קישוריות זו נשענת גם על שילוב טכנולוגיות IoT, המאפשרות גם הן ערוצי תקיפה.

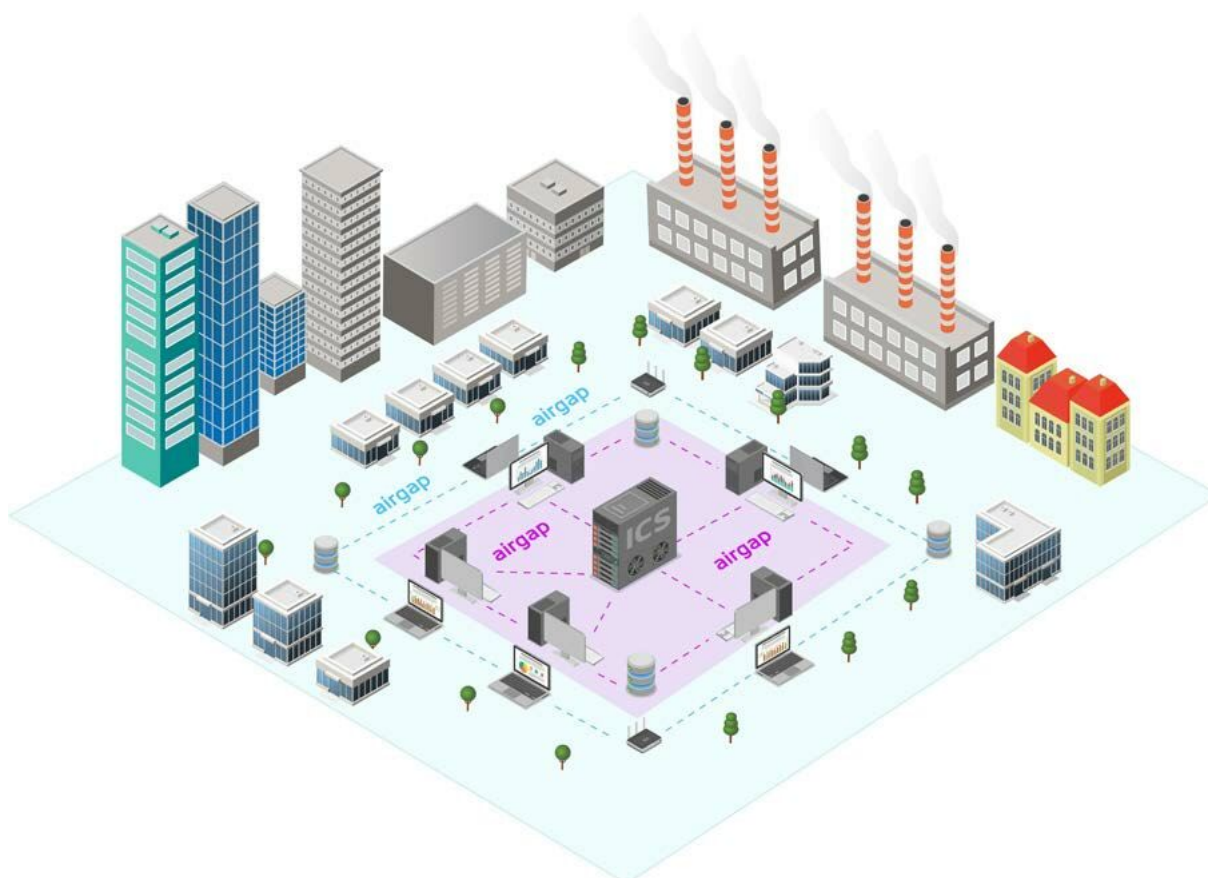
בשל היתרונות שבהתפתחות טכנולוגיות הנ"ל מתמוססת התפיסה של "רשת תפעולית מבודלת". כיום ניתן למצוא במנועי חיפוש דוגמת SHODAN גישה לממשקי ניהול של סביבות תפעוליות.

במצבים רבים, רשתות התפעול מבודלות ומופרדות מרשת האינטרנט. סידורי אבטחה אלו מקשים על תהליך ההתארגנות והחדירה בפועל. עם זאת, תקיפת רשתות ICS כרשת מבודלת מתאפשרת על פי רוב בארבעה צירים עיקריים (ובהתאם להם דרישות ותשומות ההגנה בשלבי התכנון בהמשך):

- **איום פנימי** (אירוע תפעולי, שנגרם על ידי עובד הארגון בשוגג או במזיד) - ובאירועים שבהם לתוקף הייתה נגישות פיזית (לרבות ניצול טכנאים).¹⁶
- **מיפוי וניצול הזדמנויות על ציר שרשרת האספקה** (כדוגמת ניצול בשיטות/הפעלת גורם הנותן תמיכה באתר או הטמנת תוכנה זדונית אצל ספק הצידוד).
- **ניצול ערוצי כניסה ויציאה** ותקיפה באמצעותם (כדוגמת מערכת הלבנה, עדכונים וכד').
- **תקיפות הנשענות על ערוצי תקיפה צדדית (Side Chanal Attack)** - ניצול מגבלות פיזיקליות הקיימות בסביבה המחשובית לטובת הזלגת מידע או שיבוש (כדוגמת ניצול השראות אלגטרומגנטיות לצורך שיבוש וכד').

BSI: Industrial Control System Security - Top 10 Threats and Countermeasures 2019 15

https://www.gov.il/BlobFolder/generalpage/coping_thret/he/Organizational_coping.pdf 16



איור 12: רשת מבודלת מרשת חיצונית

3.2 אתגרי ההגנה בסביבות OT לעומת IT

הבדלים בהגנה על מערכות IT אל מול הגנה על סביבות תפעוליות בכלל (OT) ועל מערכות בקרה תעשייתיות (ICS) בפרט:

בעוד אנשי ההגנה בסייבר מכירים ומנוסים בתהליכים וטכנולוגיות להגנה על סביבת המחשוב המסורתית (IT), הרי שהידע והיכולת לממש אותה תפיסה ורמת הגנה על הסביבה ההתפעולית (OT) מוגבלת. מגבלה זו נובעת, בין היתר, בשל האתגרים הבאים:

אנשים:

- **ידע -** אנשי אבטחת מידע והגנה בסייבר מכירים לרוב את נושא ההגנה על סביבות ה-IT (פרוטוקולים, מוצרים, כלים ועוד). לעתים הם אינם מבינים את השינוי הנדרש לטובת ביצוע התאמה של הידע שלהם בבואם להעריך סיכונים, לבחור פתרונות הגנה, לבצע ניטור ולהכין תוכנית להתאוששות עבור סביבות תפעוליות.
- **שיתוף פעולה -** לרוב, הגורם האמון על ניהול התפעול ותחזוקת המערכות בסביבת הייצור הינו גורם אשר אינו כפוף היררכית למנהל אבטחת המידע, או לגורם המנהל את מערכות המידע ורשתות התקשורת בארגון. היכולת לבצע ביקורות/שינויים ודרישות

הסיכון ולאחר בקורות מתאימות, המונעות את עצירת התהליך אל מול איתור בקורות מפצות, המאפשרות את צמצום הסיכון ללא פגיעה בקו הייצור.

טכנולוגיה:

- **היצע מוגבל של פתרונות הגנה ייעודיים** - בעוד שפתרונות כגון ניתוח קוד, איתור פגיעויות ועוד זמינים ומוטמעים במערכות רבות בעולם, הרי שלא תמיד הם מתאימים לפרוטוקולים הייעודיים לסביבות ICS. בנוסף, לא תמיד כלים אלו מאושרים לשימוש על ידי היצרן או על ידי המתפעלים של הציד, בשל חשש לפגיעה תפעולית, כיסוי באחריות וכד'.
- **מחזור החיים של הציד** - בעוד שציד ID מוחלף בתדירות גבוהה יחסית בארגונים ובעלויות מידתיות (ביחס למחזור הכספי של הארגון), הרי שהחלפה של בקר או רכיב SCADA כרוה במאמצים, משאבים ועלות כספית גבוהה לארגון. עובדה זו מובילה למציאות בשטח בה נמצא ציד בן 10-20 שנים ויותר, אשר נדרש להגן עליו עם הכלים הקיימים (שהם מוגבלים ואינם מתאימים לא פעם לעולם תוכן זה).
- **שימוש בטכנולוגיות ישנות ולא ניתנות לשינוי** - כדוגמת רשת שלא ניתנו לה תשומות אבטחה בתהליך האפיון וההקמה, שימוש בבקרים ישנים, פרוטוקולים ותקשורת מסורתיים המבוססים על טכנולוגיות קלאסיות ישנות שאינן נתמכות. מכאן, קיימים קשיים בהרצת עדכוני אנטי וירוס או עדכוני אבטחה וכד'.

3.3 התאמת מודל ה-CIA כמודל AIC לסביבה התפעולית

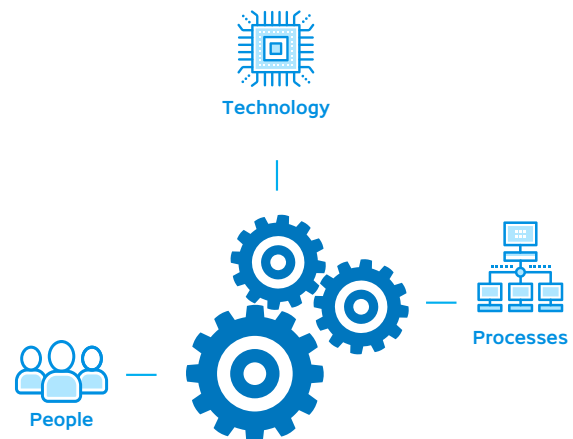
בעולם הגנת המידע, נשוא ההגנה הינו המידע. פגיעה בו עלולה להוביל לאובדן של סודות מסחריים ו/או מידע רגיש, פגיעה בזמינות של הנתונים/מידע וכן לאירועים של פגיעה במהימנות הנתונים (שיבוש המידע). מקובל לסווג אירועים אלו לקטגוריות הבאות:

- C - **סודיות המידע (Confidentiality)**
- I - **מהימנות המידע (Integrity)**
- A - **זמינות המידע (Availibility)**

הקשחה מצריכה שיתוף פעולה עמוק בין שתי היחידות השונות בארגון. בעוד שאנשי הגנת הסייבר מחזיקים לרוב בידע הנדרש לשיח מול אנשי ה-ID, הרי שהידע הנדרש לטובת שיח עם אנשי התפעול/בקרה הוא שונה (תחום ידע תלוי מגזר, כגון מושגים הרלוונטים לסביבת הייצור כדוגמת PAC, שלא קיים ברשת ה-ID,

הבנה בתהליכים כימיים/תהליכים הנדסיים וכו').

- **תלות בגורמים חיצוניים** - בעוד שבסביבת ה-ID ניתן להשתמש בעובדי הארגון ובספקים מקומיים שעמם יש לארגון היכרות טובה (לרבות בדיקות רקע/מהימנות עובדים במידת הצורך), הרי שבעבודה עם יצרנים אלו, התמיכה והתחזוקה ניתנות לא פעם על ידי גורמים מקצועיים תלויים ומותנים באחריות, ובגינם היכולת של הלקוח להשפיע עליהם נמוכה (כדוגמת, ספקית מערכת או תוכנת מומחים מחו"ל).



איור 13: הסינרגיה, שיתוף הפעולה והסנכרון בין טכנולוגיה, תהליכים ואנשים

תהליכים:

- **יכולת ועלות גבוהות לקו הייצור ולפעילות העסקית** - כל צורך בשדרוג, בעדכון או בהשבתה מתורגם מיידית לכסף רב ולסיכון לתהליך הבקרה. כחלק מצמצום סיכונים ניתן לשקול אזור ייעודי לצורכי הרצת קבצים וסימולציות כתהליך מקדים לתהליך ברשת.
- **עלות "הפסקה/השבתה"** - קושי ביכולת לאזן את

הראשונה נמצאת היכולת של הארגון להמשיך לייצר. סודיות המידע והמהימנות מקבלים רמת תעדוף מעט שונה. יצוין, כי לעתים פגיעה במהימנות הנתונים עלולה להוביל למקרים של סיכון חיי אדם ולאירועי בטיחות. במקרים אלו, גופים רבים יעדיפו את פרמטר 1 על פני הרציפות העסקית (פרמטר A). כמו כן, יינקטו תשומות לשמירה על לוגיקת הבקרים ועל בחינת החיויים מהשטח ואמיתותם.

בעולם התפעולי, לרוב המיקוד של ההגנה הינו פחות על המידע (סודיות) ויותר על היבטי בטיחות והשלכות תפעוליות עסקיות הקשורות לתהליך קו הייצור, אשר עלולות להיגרם כתוצאה ממתקפת סייבר. תוצאות אלו עלולות לגרום לפגיעה בחיי אדם, לפגיעה באיכות הסביבה ולפגיעה כלכלית גדולה לעסק (במקרה של פגיעה ברציפות העסקית). לאור זאת, מודל CIA המוכר נדרש להתאמה לשפה ייעודית, המתאימה לסביבה התפעולית, לאנשי התפעול, למהנדסי הייצור, למהנדסי התהליך וכו'.

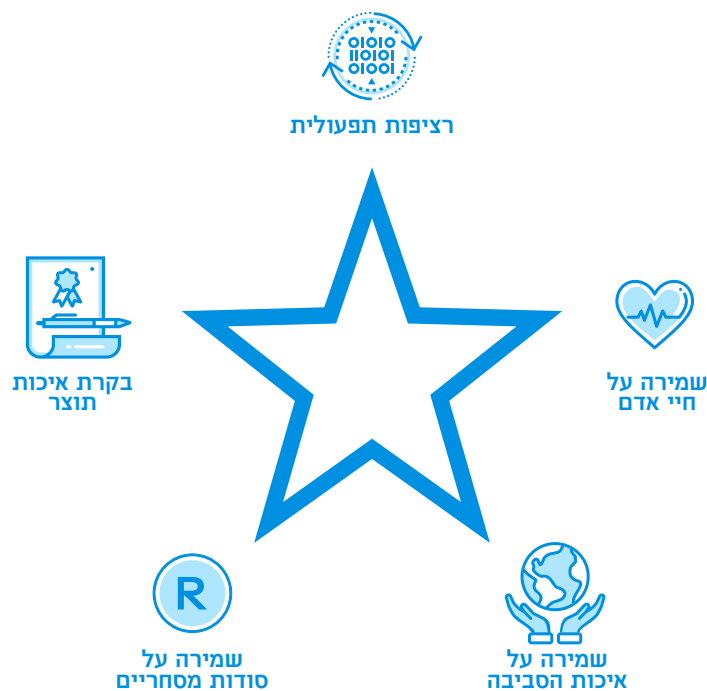
3.4 מודל הכוכב - מבוסס על NIST 8183

בעת ביצוע תהליך של הערכת סיכונים, נוכל לעבוד, לדוגמה, עם אחד משני המודלים האלה:

מודל AIC

- מודל זה מתמקד בהשלכות של הפגיעה. השלכות אלו מכוונות לנזק הפוטנציאלי כתוצאה מהתממשות אירוע סייבר על הרציפות התפעולית, שמירה על חיי אדם, שמירה על איכות הסביבה, בקרת האיכות והסודות המסחריים. מודל זה מיוצג באמצעות התרשים הבא:

- מודל זה משנה את סדר הפרמטרים של מודל CIA המוכר. השינוי מבטא את החשיבות הרבה לזמינות ולרציפות העסקית בפס הייצור. מאחר שמושא ההגנה בעולם ה-OT הינו התהליך התפעולי, הרי שבעדיפות



איור 14: מודל הכוכב

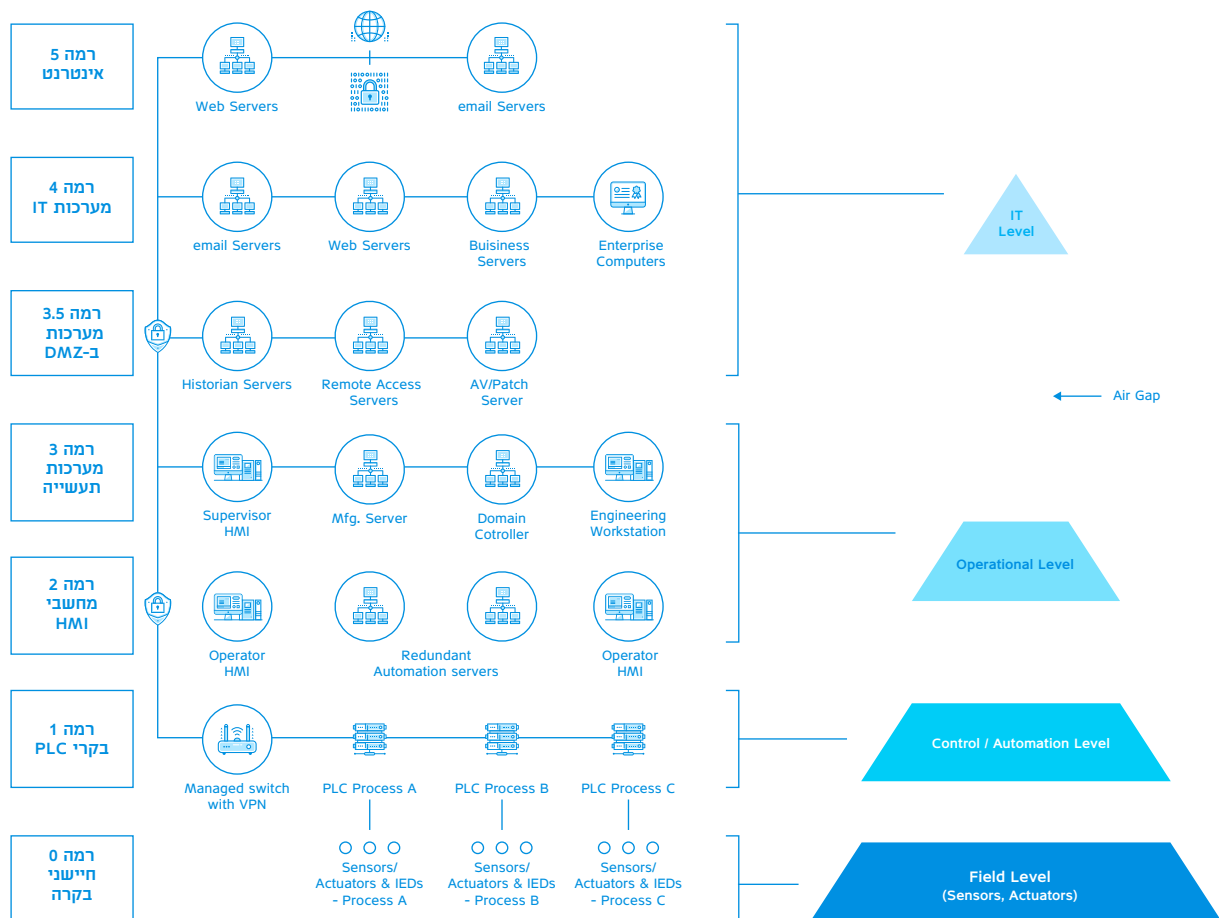
3.5 תמצית ההבדלים בין סביבת ה-IT לסביבת ה-OT:

קטגוריה	רשת בקרה תעשייתית	רשת IT
דרישות ביצועים	דיוק בסנכרון הזמן	ניתן להתפשר בדיוק הסינכרון (ולעדכן בתכיפות שונה)
דרישות זמינות	חייבת להיות זמינות רציפה, כל השבתה חייבת להיות מתוכננת זמן רב מראש	רצוי זמינות מירבית (לעתים ניתן להתפשר על נושא הזמינות - בהתאם לניהול סיכונים)
ניהול סיכונים	סיכון חיי אדם בעדיפות עליונה, זאת לצד סיכונים פיזיים, תפעוליים, רגולציה ואיכות סביבה	שמירה על מידע ופרטיות קריטיים, וסיכון עסקי (כספי, תדמיתי)
המיקוד בהגנה	הגנה על ציודי הקצה, תהליכי הייצור והמוצר המוגמר (במקרה שניתן לשבש את התוצרת, כמו מינוני מזון, תרופות)	הגנה על נכסי ה-IT והמידע המאוחסן בארגון
הרצת תוכנות ועדכונים	הרצת תוכנות ועדכונים חייבת להיבחן תחילה מחוץ לסביבת הייצור, על מנת לא לפגוע בתפקוד המערכות, עלויות גבוהות בהקמת סביבת מעבדה. מצד שני, מערכות רבות מותקנות בתצורה של יתירות וכפילות מפחיתות את הסיכון על ידי שינוי בבקר 1 ולאחר הכנסתו לעבודה ניתן לבצע את השינוי בבקר 2 וכד'. יש לוודא תשומות תיכנון לשינוי קונפיגורציה ושינוי והקשחה להגדרות DEFAULT	תוכנות ועדכונים נבנו לסביבות ה-IT ולכן מותאמות יותר
אינטראקציות בחירום	יכולת הספק/יצרן לתגובה של מפעיל וביצוע פעולות בזמן חירום הן קריטיות. לעתים גישה זו נדרשת גם בשגרה בצורה רציפה לטובת מתן התמיכה (לדוגמה, עבור מקרה שבו התממש אירוע, או עבור ניטור נתונים למטרות תפעוליות)	יכולת סגירת גישה תקשורתית בחירום, יכולת מתן מענה לאירוע באמצעות גורמים שונים ובלתי תלויים.
תפעול מערכת	ניהול שינויים קפדני, תפעול של מגוון מערכות ייעודיות	מערכות מותאמות לשינויים, מערכות מוכרות לרוב
אילוצי משאבים	המערכות מותאמות לעבודה תפעולית. לא תמיד ניתן להוסיף מערכות אבטחה בשל חוסר משאבי עיבוד וזיכרון	מערכות מתוכננות לתוספת משאבים (הגדלת זיכרון, הוספת CPU ושטחי דיסק)

קטגוריה	רשת בקרה תעשייתית	רשת זו
תקשורת	מגוון פרוטוקולים	תקשורת סטנדרטית בפרוטוקולים מוכרים
ניהול השינויים	נדרשת בדיקה מקיפה בסביבות בדיקה, נדרש תכנון מוקדם לכל שינוי	שינויים סטנדרטיים, תהליכים מוסדרים ונפוצים
תמיכה מנוהלת	תמיכה של כל יצרן בנפרד	מאפשר מגוון יכולות תמיכה
גישה לרכיבים	הרכיבים יכולים להיות מבודדים בפריסה ארצית, לרוב נדרשת הגנה פיזית נוספת	רכיבים לרוב מקובצים באתר בחדרי שרתים ובעלי נגישות
מחזור חיים של הצידוד	עשרות שנים	שנים בודדות
סובלנות לפגיעה ברציפות עסקית	בינונית	מועטה מאוד
עדכוני תוכנה	נמוך	תכוף
מודעות וידע בתחום הסייבר	לרוב נמוכה	קיימת

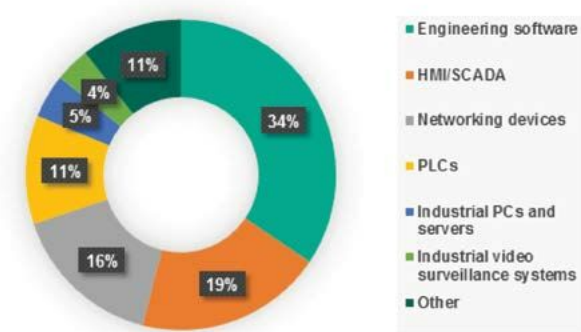
3.6 סיכוני סייבר על פי שכבות של מודל PURDUE

התקפות סייבר עלולות לנצל פגיעות בכל אחת משכבות המודל (ZONE) והמעברים ביניהם. פרק זה יסקור את התקיפות אשר מנצלות את התקשורת/ערוץ שמחבר בין שכבות המודל (כגון המעבר משכבה 0 לשכבה 1 במודל).



איור 15: אזורי חפיפה בין המודלים (PERDUE ומודל המשולש)

תוכנה (Windows XP), בעיקר עקב החשש של קריסת המערכות אחרי העדכון. מערכות אלה נמצאות בחדר הבקרה, וקיים סיכון שגורם לא מורשה יבצע פעולה לא מורשית, כדוגמת החדרת התקן USB לאחד המחשבים וגרימת התפשטות הנוזקה. בשכבה זו נמצא גם שרת הנדסה, שיש בו מידע תפעולי (Engineering Station) לגבי התוכנות בבקרים וגם תוכנות של מרכז הבקרה.



איור 16: מיפוי חולשות לפי רכיבים בסביבת ICS (אתר קספרסקי)¹⁸

3.6.6 פירוט שכבות נוספות במודל:

- שכבה 3: שכבת התפעול שבה נמצאים המחשבים ושרתי התפעול.
- מעבר DMZ-3: ברשת זו מועברים נתונים ממערכת הבקרה בפרוטוקול IP/TCP.
- שכבת DMZ: ברשת זו מופיעות מערכות מחשוב שתפקידן להימצא בתוך DMZ.
- מעבר DMZ-4: ברשת זו מועברים נתונים ממערכת הבקרה בפרוטוקול IP/TCP לסביבת מחשבי הניהול, עמדות המהנדס ותחנות עבודה.
- שכבה 5: ברשת זו מופיעות מערכות ה-IT המשרתות את מערכות ה-OT (לעתים עמדות אלו מחוברות לאינטרנט).

3.6.1 סיכוני סייבר בשכבה 0:

- בשכבה זו קיימים חיישנים ובקרים המנטרים את פעולת המכונות או אמצעי תפעול פעילים, כגון מגעים, רגשים אנלוגיים ועוד. הסיכון ברמה זו מתבטא בפוטנציאל תקיפה פיזית או לוגית, אשר תוביל לשינוי פעולות ברכיב כלשהו (חיישן, וסת לחץ, וסת טמפר', ברזים וכד'), שיבצע מדידה שגויה והזנת נתונים שגויים על ניתוח התהליכים וההשלכות הנובעות מכך.

3.6.2 סיכוני סייבר במעבר 0-1:

- הקישור בין ההתקנים ברמה 0 לבין הבקר ברמה 1 מתנהל באמצעות חיבורים חשמליים או חיבורים של תקשורת סריאלית וטורית. הסיכון ברמה זו הוא בשידור מידע פיקטיבי, וכן האפשרות לחבלה בחיווט או החלפת רכיב חומרת.

3.6.3 סיכוני סייבר בשכבה 1:

- מיפוי הבקר (PLC/RTU) שמנהל את התהליך המבוקר. הסיכונים העיקריים לאירוע זה השבתת תהליך הוא שינוי לוגיקה, קונפיגורציה או שתילת קוד חלופי אל תוך הבקר.

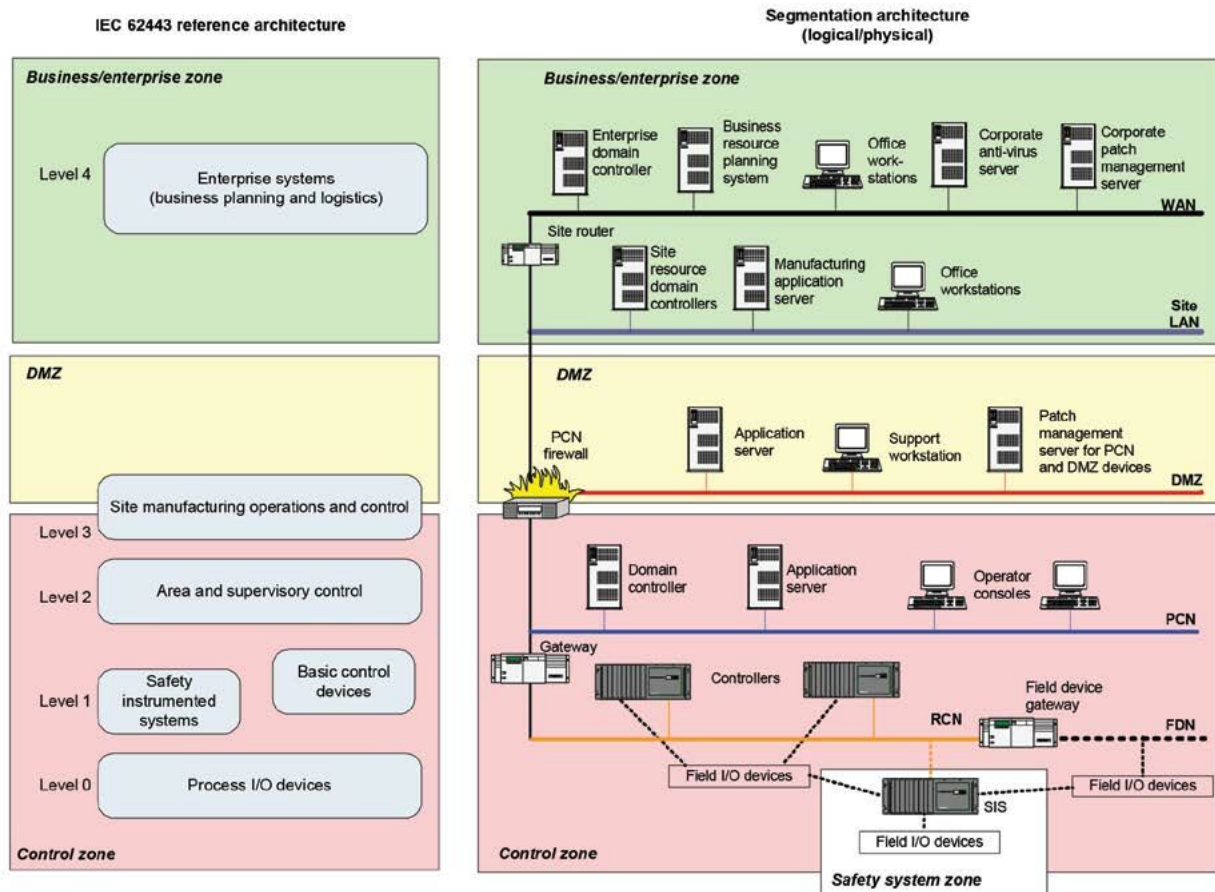
3.6.4 סיכוני סייבר במעבר 1-2:

- מעבר זה מתבסס על תקשורת רשתית (LAN) בפרוטוקולים (over TCP), כגון DNP, 3 MODBUS, PROFINET, IEC 60870-5-104 ועוד. במערכות מיושנות קיים שימוש בתקשורת טורית (232-RS), כולל פרוטוקולים כמו MODBUS, 1-DF, PROFIBUS וכו'. הסיכון העיקרי הוא היכולת להתחבר למערכת, בייחוד אם התקשורת היא אלחוטית (לא מוצפנת) וגם היכולת לגשר בין רשתות ולבצע התערבות בתהליך. קונפיגורציה לקוייה של מערכות ההגנה (כדוגמת ה-Firewall) בין השכבות והרכיבים תאפשר לתוקף לנצל פורטים פתוחים לצורך המשך והתפשטות שלב התקיפה ברשת.

3.6.5 סיכוני סייבר בשכבה 2:

- בשכבה זו נמצא מרכז/שרת הבקרה, המנהל את התהליך וכולל את מחשבי HMI. יש לקחת בחשבון שקיימות מערכות HMI אשר לא מקבלות עדכוני

https://ics-cert.kaspersky.com/media/KL_ICS_CERT_H2_2018_REPORT_EN.pdf 18



איור 17: מיפוי רכיבים במודל השכבות (תקן IEC-62443-3-1)

- הגדרת חוקים למניעת תקשורת לא מורשית פנימית וחיצונית.
- הגבלת גישה מרשת הארגון (הרשת המינהלתית) לרשת התפעולית באופן המונע שאילתות או העברת פקודות ישירות לבקרים.
- וידוא של התאמת הגדרות ויכולת גילוי וזיהוי איומים בפרוטוקולים בסביבת ה-OT של הארגון
- הגדרות FW מתאימות לתמיכת ספקים מחוץ לארגון.

מימוש (FW) Firewall בסביבת ICS הינו אירוע מורכב בסביבת תפעול, לעתים בשל סיבות בטיחותיות וכד'. החלוקה וההגדרות צריכות להיות בהלימה ובהתאמה למודל PURDUE ובהתאם לקווים המנחים האלה:

- תכנון ה-FW ייתן מענה לתנועות שבין סביבת ה-OT וה-IT ולאירועים הקלאסיים והבעייתיים לסביבות ה-ICS, לרבות תקיפות ממוקדות, תקיפות APT וכד'.

<https://www.energy.gov/sites/prod/files/Good%20Practices%20Guide%20for%20Firewall%20Deployment.pdf> 19

לאינטרנט (מחוץ ופנימה) - במטרה למנוע תקשורת לא רצויה, התקפות עומס (DOS), השחתה או מניעה של הודעות ייעודיות בתוך הפנימי.

שכבה 3 - יינתנו תשומות ייעודיות לבידול מול שכבה 20,4

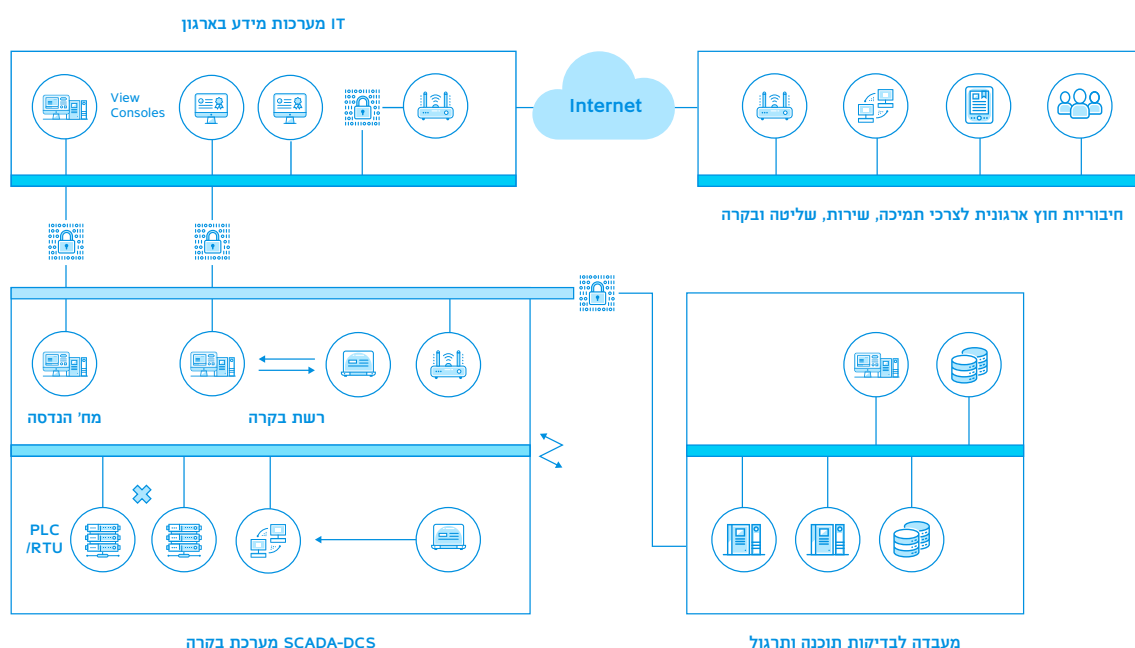
שכבה 0-2 - שכבת מערכות השליטה, ה-HMI ותפקידה לאפשר צפייה ובקרה של תהליכי שליטה ובקרה, לאפשר התערבות המפעיל על פי הצורך וההרשאות הניתנות לו. הגדרות וחוקי ה-FW שיש ליישם הם כנגד עקיפת תקשורת, ביצוע פעולות לא אפשריות שיש בהן סיכון לגרימת נזק ופעולות לא מורשות (הן בחוקים והגבלת התקשורת הלא רצויה מהשכבות מעלה והן מהשכבות מטה).

- הגדרות FW מתאימות לקישוריות אלחוטיות (ככל שנדרשת ולאחר תהליך אישור בארגון) - תוך מטרה למנוע תקשורת לא לגיטימית וניצול הזדמנויות תקיפה בערוצים אלו.
- תהליך לאיסוף וניתוח מזהי תקיפה וטיוב הגדרות בהתאם.
- תשומות לניהול הרשאות חזקות לשינויים במערכת ה-FW.
- כחלק מתהליך הבטחת עמידה בדרישות בטיחות יש לוודא, כי אמצעי ההגנה והגדרות ה-FW אינם יוצרים נקודות כשל.

דגשים להגדרות FW ייעודיות על פי מודל PURDUE:

3.6.7 התייחסות למבנה המערכותי הכולל בארגון
באופן שונה ממודל PURDUE וגם ממודלים אחרים, יש התייחסות לארבעה אזורים המחוברים זה לזה:

- **שכבות 4-5 -** לעתים מדובר בסביבה המחוברת לרשת האינטרנט או למערכות המקושרות לרשת האינטרנט, ועל כן, בשכבה זו יש לוודא יישום והגדרה של חוקים למניעת תקשורת ישירה ופתוחה



איור 18: ממשקים באזורי החיבור

<https://www.sans.org/reading-room/whitepapers/ICS/secure-architecture-industrial-control-systems-36327> 20

התייחסות לחיבוריות ה-IT

- החיבוריות בין סביבת ה-IT וסביבת ה-OT קיימת גם בסביבות תעשייתיות. זאת, כדי לאפשר סביבת ניהול לביצוע העבודה. החיבוריות לתשתיות IT (ולעתים החיבור לאינטרנט) חושפות את הרשת לסכנות רבות.

מעבדת הבדיקות למערכת

- מערכת זו כוללת מערכת בקרה, שמדמה את המערכת האמתית (Digital Twin). סביבה זו מחוברת באופן מאובטח למערכת הבקרה ומשמשת לבדיקות תוכנה, לתרגול של מפעילים ולבדיקה של התקנים. הגם שקיימים מנגנוני אבטחה וקישוריות מאובטחת, קיימת סכנה של זליגת פוגענים מתוך סביבה זו.

חיבוריות חוץ-ארגונית לצרכי תמיכה, שירות, שליטה ובקרה

- אזור זה כולל את הגורמים החיצוניים הנדרשים להתחבר למערכות, בהם ספקים, נותני שירות תמיכה, עובדים התומכים מחוץ לארגון וכד'. החשש והסכנה הם לניצול חיבוריות זו לצורכי תקיפה (בתוך כך איומי Man In The Middle (MITM), מתקפת Denial of Service (DOS), ניצול הרשאות על ידי גורמים עוינים ועוד). סביבת מערכות התפעול והבקרה (קו הייצור). סביבה זו כוללת את תהליך הייצור, את מחשבי המהנדסים, את מערכות ה-HMI ואת הבקרים.

««« 4. הערכה וניהול של סיכונים במערכות ICS ועקרונות למענה בתוכנית עבודה

4.1 תהליך ניהול סיכוני סייבר כחלק מהערכה וניהול הסיכונים

מטרתו של תהליך ניהול סיכוני סייבר היא לבחון את

הסיכונים הארגוניים ובהמשך להפחית את השפעתם של אירועים חריגים על הארגון. התהליך כולל את ניסוח תרחישי הסיכון העשויים לפגוע בארגון, הערכת פוטנציאל הנזק בעת התממשותו, הערכת הסבירות להתממשות התרחיש, תעדוף בקורות לטיפול בתרחישים על פי עוצמתם, שהינו שילוב בין השפעת הסיכון ובין ההסתברות להתממשותו, ולבסוף אפיון תוכנית עבודה להפחתת הסיכון.²¹

תהליך ניהול סיכונים במערכות ICS הוא תהליך חשוב ומורכב. מערכות ICS הן מערכות קריטיות מבודדות,

המשתמשות בפרוטוקולים שונים ולעתים מעורבים, בחומרה ובתוכנה. מנגד, הידע הקיים אצל אנשי המחשוב, עלויות התפעול, התחזוקה, השדרוגים והימנעות מפגיעה רציפה בתהליך הייצור (כדוגמת הדילמה של הרצת עדכון טלאים בסביבת ייצור) מאתגרים ומייחדים את תהליך ניהול הסיכונים בסביבת ה-ICS בהשוואה לסביבת ה-IT. תהליך זה הוא תהליך המתבצע באופן מחזורי בהתאם לשינויים טכנולוגיים, ארגוניים, איומים ויכולות תקיפה חדשות וכד'. מטרת התהליך היא **ביצוע הערכה נכונה של הסיכון באופן המקובל על כלל הגורמים בארגון** (הנהלה, אנשי קו הייצור וגורמי המחשוב) ובהמשך - תרגומה לתוכנית עבודה ייעודית להפחתת השפעתם של אירועים חריגים ולמניעת נזקים כדוגמת אירועי בטיחות, פגיעה בחיי אדם או פגיעה בקו הייצור.



איור 19: תהליך ניהול סיכוני סייבר ובניית תוכנית עבודה לסביבת ICS

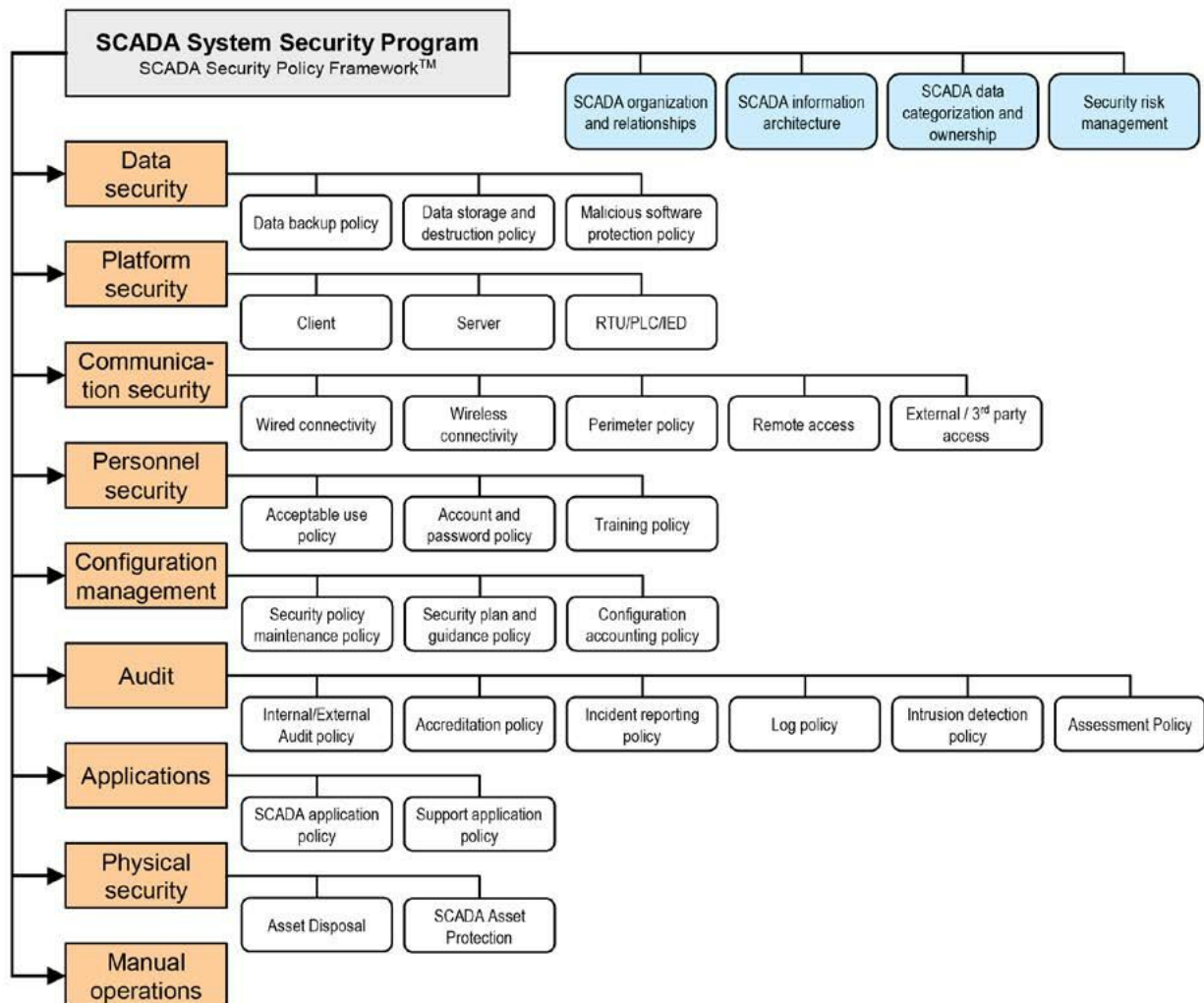
<https://pdfs.semanticscholar.org/cb14/b23b9d0d4242edb1057b722e7a6f923d4885.pdf> 21

4.2 מיפוי הסיכונים

מיפוי הסיכונים מתבסס על התהליכים הבאים (והסינרגיה ביניהם):

- מיפוי נכסים - שלב המיפוי קושר גם בין נכסי IT/OT (ראו פרק 5.2 בתורת ההגנה).²²
- מיפוי סיכונים הנובעים מחוסר מדיניות (על ידי מיפוי אזורים ונושאים ללא מדיניות).

איור 20 להלן מאפשר לגבש מדיניות לפי אזורי פעילות מצד אחד, ומצד שני לאתר סיכונים באזורים שלא קיימת בהם מדיניות.



איור 20: Framework למדיניות אבטחת SCADA בארגון

²² תורת ההגנה בסייבר לארגון - https://www.gov.il/BlobFolder/policy/cyber_security_methodology_for_organizations/he/Cyber1.0_418_A4.pdf

תהליך המיפוי יתבצע באופן הבא: תיאור ארכיטקטורת המערכת ותיאור ממשיקי הרכיבים - שתאפשר **תמונת מצב ויזואלית של סביבת הרשת והתלות בין רכיבים מגוונים** ומסוגים שונים (לדוגמה, כמה בקרים שונים) - תקשורת ופרוטוקולים, והצבעה **על סיכונים הנובעים ממדיניות, מחולשות מובנות בחומרה ותוכנה וכד'.**

תהליך מיפוי הסיכונים ביחס לתהליכים אלו מחייב:

- הכרת התהליך העסקי והרכיבים המשמשים אותו (לרבות מיפוי סנסורים, רשתות ותת-רשתות, סוג תקשורת, רכיבים משתתפים וטופולוגיה לוגית של הסביבה).

- זיהוי תרחישי סיכון, המתבסס גם על מודיעין ועל היסטוריית אירועים בארגון ובסקטור -** תהליך המלווה גם בסקירת תהליכים קריטיים של הארגון ואופן היתכנות ההשפעה על תהליכים אלו. תרחישי הסיכון נשענים, בין היתר, על: בעלי האינטרס לתקוף את הארגון, יכולותיהם והכלים העומדים לרשותם ותקיפות עבר.

ניתן להיעזר בבנק תרחישים, או בטבלת סיכונים נפוצים, דוגמת זו המופיעה בסקירה שבמסמך זה, או בטבלה כגון זו:

1. סיכון הנובע משימוש במערכות ישנות שלא נתמכות, אינן בעלות יכולת אבטחה מתקדמות, וכן מהיעדר זמינות של עדכוני אבטחה סדורים (End of life)	6. סיכוני סייבר הנובעים מתהליכי שרשרת אספקה (כדוגמת דלתות אחוריות ותהליכים בעלי פוטנציאל סיכון על ציר שרשרת האספקה, כמו שימוש במחשב טכנאי המשותף לתמיכת כמה לקוחות שונים)
2. סיכונים בחיבוריות רכיבים בעלי ממשקים אלחוטיים	7. פערי אבטחה ודלתות אחוריות מובנות בתוכנה (חוסר יכולת בשילוב פתרונות הגנה צד' ג')
3. הגדלת משטח תקיפה בעקבות שימוש תדיר בקישוריות לא מאובטחת (ערוצי השתלטות, תמיכה ולצורך הורדת עדכונים)	8. הזדמנויות חדירה פיזית וחוסר תשומות למניעת
4. מצוקת כוח אדם של מומחי סייבר בפס הייצור (שלב התכנון, התמיכה, ניהול סיכונים וכד')	9. מדיניות לא סדורה בתהליכי עדכונים של אנטי-וירוס וטלאים (אבטחה ותפעול)
5. סביבות לא מבודדות, המאפשרות דילוג והתפשטות בין רשתות	10. שגיאות אדם (מפעיל), העלולות לגרום לפערי אבטחה ולהזדמנויות אטרקטיביות לתוקף

- הערכת ההשפעה של הנוק הצפוי במידה שיתממש** על תהליך התפעול, אירועי בטיחות, נזקים תפעוליים כדוגמת השבתת מערכת או בקר ייחודי באופן שיפגע בקו הייצור, נזקים פיננסיים וכד'.
- הגדרת מענה הגנתי ובקורות מפצות נדרשות.**

שימו לב: לטובת קבלת תבנית לדוגמה עבור ביצוע סקר סיכונים בסביבות תפעוליות ולטובת העלאת המודעות לנושא בקרב הנהלת הארגון, ראו מסמכים משלימים **באתר מערך הסייבר הלאומי**²³ בנושא.

²³ https://www.gov.il/he/departments/topics/organization_cyber_protection

4.3 ניהול סיכונים בסביבת ICS לעומת ניהול סיכונים בסביבת ה-IT

תהליך ניהול סיכונים בסביבת ICS שונה מתהליך ניהול סיכונים בסביבת ה-IT:

גורם	IT	OT/ICS	הערות
חיבור לתהליכים העסקיים	חשוב	הכרחי	לא ניתן לבצע הערכת סיכונים לסביבה כזו ללא הכרה של התהליך כפי שהוא עולה משיחות עם מהנדס התהליך ועם גורמי התפעול. איתור איומים ופגיעויות לא מתאפשר ללא הבנה מעמיקה של זרימת המידע ומרכיבי התהליך לעומק.
יכולת הגנה	קיימים פתרונות הגנה מסחריים, וידע מקצועי רב זמין בתחום	פתרונות הגנה רבים אינם מתאימים, מסורבלים ו/או אינם רלוונטיים לסביבה זו. היכולת המשפטית והתפעולית להתקין פתרון הגנה וכלי ניטור לבצע סריקה וכו' בסביבה זו מוגבלת מאוד	קיימים פתרונות מסחריים ייעודיים לעולם ה-ICS, אך הם זמנים פחות מאשר פתרונות לסביבת IT שם ההיצע רחב יותר ומנוסה יותר בשטח. בנוסף, התנגדות אנשי התפעול להתערבות והשפעה על התהליכים התפעוליים גדולה מאשר התנגדות שקיימת לעיתים להתקין רכיב הגנה על שרתים ורשתות בסביבת ה-IT. בדרך כלל הפיתרון תלוי בספק הבקרה. לא ניתן להכניס פיתרון חיצוני.
שיקולים של שונות סביבת מורכבת	סביבה אחודה	סביבה מורכבת	קיימת שונות בין הסביבות ושיקולים מורכבים של סביבת OT שקיימים בה ציודים שאורך החיים שלהם הוא 15 שנים, וכן סביבה שלא מתקיימים בה עדכוני תוכנה באופן סדור, ופרוטוקולים שונים ומסואבים. אלו נובעים, בין היתר, בשל הצורך התפעולי בפס הייצור. ²⁴
פוטנציאל הנזק	לרוב הנזק יהיה כספי, עם נזקים משניים של מוניטין, פרטיות ועוד	הנזק יכול להתבטא גם בהפסקת קו ייצור ובפגיעה בחיי אדם	נזקים שמשמעותם פגיעה באורח חיים תקין (גם ברמת מדינה)
מסקנה	בהגנה על סביבות ICS הארגון מתמודד עם יכולת הגנה מוגבלת מאוד מול גורמים בעלי משאבים ואינטרס, אשר עלולים לגרום נזק עצום. הדבר מעצים את הצורך של ארגונים לחזק בעיקר את יכולת הניטור והתגובה שלהם בהגנה על סביבות מסוג זה.		

««« 5. בקורות על מערכת ICS

ה-ICS, לרכיבי המחשוב, למערכות המתממשקות ולטכנולוגיות. הצלחת היישום וההטמעה של בקורות האבטחה לצמצום הסיכונים תלויה בארגון, בגודלו, באופי פעילותו ובמורכבותו (באופן זה, ייתכן שבקורות מסוימות יצמצמו את הסיכונים לסביבות מעורבות בעוד שבסביבות מבודדות ניתן יהיה לוותר על מקצתן). תהליך נכון לבחירת הבקורות המתאימות והטמעתן כרוך בתהליך ניהול סיכונים מתאים.

הגנת סייבר על מערכות ICS דורשת לשלב הגנה ב"מעגלי אבטחה" תוך שימוש בכמה שיטות וטכנולוגיות להגנת סייבר. הואיל ולא קיימת טכנולוגיה יחידה כלשהי שישגימה עבור כל סוגי המערכות, נדרש לבצע מגוון סוגים של בקורות, המותאמות במיוחד לרמת הסיכון, ליישום של המערכת, לשנות הפעילות של המערכת, למבנה המערכת, לטכנולוגיות נתקשורת, למרחב הגיאוגרפי שעליו פרוסה המערכת (עיר, מפעל, בניין) ועוד. בנק הבקורות המובא בטבלה הינו ייעודי ומתאים לסביבת ה-ICS. הבקורות המובאות בהמשך נבחרו בהתאם לסביבת

5.1 בקורות להגנת סייבר במערכות ICS (בהלימה למשפחת בקרים תעשייתיים - תורת ההגנה)

זיהוי בקרה	כותרת	הבקרה	הסבר משלים	דוגמה ליישום הבקרה	עומק בקרה*
12.1	מדיניות בקרים תעשייתיים	יש לכתוב, לנהל ולבקר מדיניות ארגונית להגנה על סביבות בקרים תעשייתיים. מדיניות זו תגובה, בין היתר, במתן כתב מינוי והגדרת תפקיד, הכוללת קביעת חלוקת אחריות בין בעלי תפקידים וגורמים האחראים על רשת ה-OT ועל רשתות משיקות.	הארגון יגדיר את המדיניות שלו בנושא המערכת התפעולית, לרבות התייחסות למדיניות גישה מרחוק, שדרוגי גרסאות, עדכוני תוכנה, תחזוקה על ידי צד ג' ועוד.	ניתן ליישם באמצעות כתיבת מדיניות ונהלים תומכים, אשר מגדירים את הדרישות הייחודיות לסביבת הבקרים התעשייתיים ובהתייחס לאופי סביבת הבקרים (ייצור/לוגיסטיקה/בקרת סביבה/ייצור כוח ועוד). יש להתייחס להיבטים רגולטוריים קיימים על סביבות אלו (לדוגמה: FDA, GXP, מערך הסייבר). יש לוודא, כי מסמך המדיניות מסדיר ומגדיר את הגורם האחראי על התחום בארגון. חלוקת האחריות תתייחס לתחומים השונים, כגון מיהו הגורם שאחראי לביצוע עדכוני תוכנה, לניטור התחברות ספקים, להכנסת קבצים לטובת ביצוע שדרוגים וכו'. מומלץ, כי הגורם האמון על הגנת הסייבר של סביבת ה-ICS יהיה בעל כתב מינוי רשמי חתום ומאושר על ידי ההנהלה של הארגון.	2

* מורכבות רמת הבקרה מ-1 (קל) עד 4 (מורכב)

זיהוי בקרה	כותרת	הבקרה	הסבר משלים	דוגמה לישום הבקרה	עומק בקרה*
12.2	מדיניות בקרים תעשייתיים	יוגדרו כללי שימוש נאות בציד בסביבת הייצור ויוצב שילוט המסביר כללים אלו.	הארגון יגדיר שילוט, המסביר את נוהלי אבטחת המידע בתחנות העבודה אשר שולטות ומבקרות את סביבת הייצור.	השילוט יכלול את מדיניות השימוש בתחנות העבודה המשותפות, שימוש בהתקני מדיה נתיקה, התנתקות משתמשים ועוד.	1
12.3	מדיניות בקרים תעשייתיים	יש להגדיר את התהליכים הרגישים שבהם קיימות סביבות ייצור ומערכות בקרה תעשייתיות לפי מידת רגישותם.	הארגון ימפה את התהליכים שקיימות בהם סביבות ייצור ומערכות בקרה ויגדיר את התהליכים הקריטיים העיקריים לעסק המעריבים בקרות אלו, על מנת להבין את רמת הפגיעה העסקית והרגולטורית מכל סביבה כזו.	מסמך מיפוי תהליכים וסביבות לפי רמת סיכון. יש לשים לב, כי מסמך זה מנוהל ונשמר במיקום בטוח בארגון וכי הוא מתוקף בצורה עתידית. אל מול מסמך זה ניתן לשייך תרחישי תקיפה רלוונטיים ואת המענה הקיים/רצוי בהתאם (הגנה מותאמת רמת איום ופגיעויות). יש לשים לב, כי העמדות/התחנות הרגישות יוקשחו בהתאם לרמת רגישותן ולפוטנציאל הנזק, לרבות: הגדרת המחשב לכתובת IP קבועה ברשת, מערכות הפעלה נתמכות, מדיניות עדכונים וטלאי אבטחה ואנטי וירוס. תבוצע נעילה של ה-Security Policy של עמדת המפעיל. ביטול תוכנות ופורטים לא חיוניים, הגבלת גישה, חסימת מצעים אוגרי מידע, חסימת תקשורת Wi-Fi, סלולר ובלוטות', נעילת עמדות לאחר פרק זמן של חוסר שימוש במידת האפשר (בפרט באזור שאינו מאויש).	2
12.4	תקשורת בקרים תעשייתיים	יש לבדל את רשתות הבקרה ממערכות אחרות ומרשתות חיצוניות.	הארגון יבודד את רשתות הבקרה מרשתות משתמשים או שרתים לרשתות נפרדות באופן המגביל גישה ישירה בין הרשתות.	ההפרדה יכולה להתבצע באמצעות שימוש בחומות אש VLAN - נפרדים לכל רשת בקרה. בהינתן האפשרות עדיף להפריד על ידי דיודה חד-כיוונית לצורך ייצוא מידע מסביבת הייצור.	2
12.5	תקשורת בקרים תעשייתיים	יש להפריד בין מערכת הניהול של בקרי ציד תעשייתי ובין הרכיבים האופרטיביים של המערכת.	יש ליישם הפרדה נאותה בין רשת הבקרים האופרטיביים ובין מערכת הניהול של הבקרים.	במקרה שבו המערכת מחברת את רצפת הייצור לסביבות גבוהות לטובת הפקת דו"חות ניהוליים או לצרכים אחרים, ובפרט במקרים שבהם הסביבה התפעולית מחוברת לענן, יש לוודא קיום בקרות בהתאם למופיע בפרק "ענן" של מסמך זה או תקן מקביל.	2

זיהוי בקרה	כותרת	הבקרה	הסבר משלים	דוגמה לישום הבקרה	עומק בקרה*
12.6	תקשורת בקרים תעשייתיים	אין לחבר התקנים שאינם בקרי סביבת ייצור לרשת בקרי הייצור.	הארגון לא יתקין ציוד שאינו חלק ממערך רשת הבקרים התעשייתיים ברשת הבקרים. ציוד אשר נדרש לחברו יחובר לאזור רשת נפרד, ותקשורת תאפשר באופן פרטני.	אם נדרש לחבר ציוד שונה, אשר דורש חיבור לטובת ממשקים למערכות הייצור, יש לחברו בסגמנט רשת נפרד מאחורי חומת האש.	1
12.7	תקשורת בקרים תעשייתיים	גישת ספקי תמיכה לרשת הייצור תאפשר בהרשאה מראש וכן באמצעות תקשורת מאובטחת, מזוהה, ואשר מאפשרת רישום והקלטת פעולות הספק עם השלמת התמיכה יתבצע ניתוק פיזי יזום על ידי הארגון.	הארגון יטמיע מערך תקשורת מאובטח לגישת ספקים ויבקר את גישת הספק לארגון באמצעות מתן הרשאה מראש לכל התחברות ספק לרשת הבקרה.	ניתן ליישם באמצעות מערך VPN לשרת ניהול ומשתמשים ייעודיים לכל ספק (בעדיפות למשתמש לכל עובד של הספק), אשר יינעלו בשוטף ויפתחו אך ורק במידת הצורך. מומלץ, כי במידת האפשר, ספקים חיצוניים לא יתחברו ישירות לרשת הבקרה, אלא לשרת מבודד, אשר יש לו גישה ספציפית לרשת הבקרה עבור התחברות מרחוק ופעילות תחזוקה.	2
12.8	תקשורת בקרים תעשייתיים	לא תאפשר גישה ישירה לאינטרנט מסביבת בקרים תעשייתיים וכן מסביבת ממשקי אדם-מכונה.		ניתן להגביל את רשתות הבקרה בחומת האש ולא לאפשר תקשורת ישירה לאינטרנט מרשתות אלו, וכן לשלב מערכות הלבנת קבצים לתהליך מאובטח בהעברה בין סביבתית.	2
12.9	תקשורת בקרים תעשייתיים	יוגבלו שירותים לא נחוצים בסביבת הייצור ובמערכות תומכות, כגון ממשקי אדם-מכונה וחיישנים חכמים.	הארגון יבטל ו/או יגביל שירותים לא נחוצים על כלל המערכות בסביבת הבקרה, בין אם ברמת מערכת הפעלה, רמת התקשורת והן רמת האפליקציה.	ניתן להתבסס על מסמכי הקשחה של יצרני מערכת ההפעלה ואפליקציות ולכבות שירותים, לחסום פורטים, להגביל גישה אפליקטיבית לפונקציות מסוימות ועוד.	2
12.10	תקשורת בקרים תעשייתיים	יש להשתמש בתקשורת אמינה בין ציודי הקצה לבקרים התעשייתיים במידת האפשר.	יש להשתמש בפרוטוקולים אשר מאפשרים אימות המקור והיעד והצפנה של התווך בצידוד תומך.	בכל מקרה שבו ניתן להשתמש בגרסאות המאובטחות של פרוטוקולים אלו. יש להשתמש בגרסאות בטוחות ועדכניות (SSH, HTTPS, SNMPv3) - יש לעקוב אחר גרסאות חדשות בהתאם להתפתחות הטכנולוגיה).	2
12.11	תקשורת בקרים תעשייתיים	יוגדר מערך תקשורת חד-כיווני לסביבת הייצור.		יש להגדיר כלים להעברת תקשורת חד-כיוונית בין חיישנים ומערכות בסביבות רגישות.	4

זיהוי בקרה	כותרת	הבקרה	הסבר משלים	דוגמה לישום הבקרה	עומק בקרה*
12.12	תקשורת אלחוטית	רשתות אלחוטיות בסביבת הייצור יופרדו מרשתות אלחוטיות ארגוניות.	הארגון יטמיע רשת אלחוטית ייעודית, שתופרד מהרשת האלחוטית הארגונית ותשמש אך ורק לטובת תקשורת ברשת הבקרה. רשת זו לא תנותב לרשת הארגונית ולהיפך.	יש להעדיף שלא להשתמש כלל ברשתות אלחוטיות ברשת הבקרה, אך אם הדבר נדרש לצורך עסקי, הקמת רשת זו תהיה בנפרד, ניהולה יהיה בנפרד והיא לא תוצמד ל-VLAN כלשהו של הרשת התפעולית.	1
12.13	תקשורת אלחוטית	תקשורת אלחוטית בסביבת הייצור תוגבל באמצעות פרוטוקולים מאובטחים.		יש להשתמש ב-WPA-2 PSK, במידת האפשר מומלץ להשתמש בגרסה מבוססת תעודות דיגיטליות לרשתות אלחוטיות אלו.	1
12.14	תקשורת אלחוטית	יוגדר משתמש נפרד לכל לקוח קצה ברשת אלחוטית בסביבת הייצור.	הארגון יגדיר משתמש נפרד לכל אדם ולכל ציוד ברשת האלחוטית.	מומלץ לחבר את הרשת האלחוטית לשרת Radius ייעודי, אשר יאמת משתמשים לרשת זו ויאפשר לנהל אותם.	2
12.15	ניהול בקרי אדם-מכונה	הגישה לממשקי אדם-מכונה תאופשר באמצעות משתמשים אישיים לכל מפעיל.	הארגון יגדיר משתמש אישי לכל אדם העובד מול ממשק אדם-מכונה. במידה שהעמדה הינה עמדה שיתופית, ניתן להשתמש בהזדהות בכרטיסים חכמים.		2
12.16	ניהול בקרי אדם-מכונה	הגישה לממשקי אדם-מכונה תאופשר באמצעות הזדהות חזקה.	הארגון יגדיר הזדהות חזקה בגישה לממשק אדם-מכונה.	ניתן להשתמש במגוון אמצעים, כגון ביומטריה, כרטיסים חכמים, OTP ועוד. כמו כן, יש לוודא, כי ממשקים לציוד רגיש, כגון עמדת הניהול/הנדסה, ממשקי אדם-מכונה וכו' מבצעים שימוש בשמות משתמש ייחודיים ומנוהלים. רצוי, כי שימוש בחשבונות אלו יתבסס ככל האפשר על הזדהות חזקה.	4
12.17	ניהול בקרי אדם-מכונה	יותקנו מערכות ניטור ורישום פעילות על שרתי ניהול.	הארגון יגדיר מערכות הקלטת פעילות/רישום לוגים בדגש על שרתי הניהול של סביבת הייצור.	ניתן להשתמש במגוון אמצעים, כגון כלים להקלטת מסכים ופעילויות משתמש, רישום לוגים של אפליקציה ודומיהם.	2

זיהוי בקרה	כותרת	הבקרה	הסבר משלים	דוגמה ליישום הבקרה	עומק בקרה*
12.18	בקרת קוד זדוני	יותקנו כלי עזר, כגון כלי זיהוי חדירות לרשתות סביבת הייצור.		ניתן ליישם באמצעות כלי IPS רשתי/ כלי HIPS וכלים דומים, כגון Honeypots. יש לוודא, כי הפתרון הינו פאסיבי ואינו מצריך שינוי טופולוגי באופן המשפיע על הרשת. כמו כן, יש לוודא, כי הפתרון לא מייצר FP alerts.	3
12.19	בקרת קוד זדוני	יותקנו כלי וידוא חתימות קבצים (Integrity Checking) לסריקת הקבצים המועברים לסביבת רשתות הייצור.		ניתן ליישם באמצעות מגוון כלי File Integrity Checking.	3
12.20	בקרת קוד זדוני	יותקנו כלים ייעודיים כנגד נזקקות בממשקי אדם-מכונה.		ניתן ליישם באמצעות כלי anti-malware ייעודיים, המתאימים לסוג המערכת.	1
12.21	עדכוני תוכנה	עדכוני תוכנה של היצרן יותקנו על סביבות נמוכות (סביבות בדיקה) טרם התקנתם בסביבת הייצור.	הארגון יוודא בדיקה של עדכונים בסביבת בדיקות ויריץ לאורך זמן לצורך בדיקת יציבות המערכת והתהליך. במידת האפשר, יוקצה ציוד מחשוב ארגוני ייעודי לטובת פעילויות תמיכה ושדרוג. יש לוודא בציוד הייעודי מדיניות אבטחה ותחזוקה של עדכוני טלאי אבטחה ואנטי-וירוס. יינתנו תשומות פיזיות מתאימות למידור המחשב ולהבטחת שימוש רק לצורך זה.	ניתן ליישם באמצעות הקמת סביבה נמוכה (לפחות חלקית), הפניית התקשורת לסביבה זו בזמן חלון תחזוקה על סביבת הייצור ובדיקת התהליך.	2

זיהוי בקרה	כותרת	הבקרה	הסבר משלים	דוגמה לישום הבקרה	עומק בקרה*
12.22	עדכוני תוכנה	יותקנו עדכוני מערכת הפעלה הנתמכים על ידי הספק בסביבת הייצור. לרבות עדכוני לבקרים ואפליקציות בסביבת הייצור.	הארגון יטמיע בתוך פרק זמן סביר עדכוני מערכת הפעלה ואפליקציה כפי שנתקבלו מיצרן המערכת וידרוש מהספק עדכוני אבטחה לליקויים חמורים שמתפרסמים.	כחלק מתהליך זה, יש לוודא התייחסות לשיטת הכנסה בטוחה של ציוד חדש (כגון התקנים ומכונות לרשת ה-OT) וסביבת התפעול). לאור רגישות הנושא, יש לוודא יכולת להחזרת מערכת ההפעלה והתוכנות למצב התחלתי (מצב 0), זאת על ידי שימוש ב-Firmware/OS ממקור אמין ושכתוב של מידע היסטורי שהגיע עם הציוד.	2
12.23	עדכוני תוכנה	כלי "נעילת תצורה" יותקנו על מערכות "סוף מחזור חיים" (End Of Life), ובהם מערכות הפעלה מיושנות.	הארגון יטמיע כלים, אשר נועלים את תצורת המערכת לתצורה "נקייה" במידה שאין דרך לעדכן את הציוד.		3
12.24	מדיה נתיקה בסביבת הייצור	תוגבל היכולת להחדרת מדיה נתיקה לציוד הייצור, ובכלל הבקרים, ממשקי אדם-מכונה וכן חיישנים.	יש להקצות מצעים אוגרי מידע ייעודים לטובת שימוש ברשת ה-OT לטובת מזעור משטח החשיפה וצמצום הסיכון לדילוג בין רשתות. יש לשים לב למקרים שבהם ציוד פרטי של עובדים מתחבר לעמדות, כגון במקרה שבו עובדים בפס הייצור מחברים לטעינה מחשוב, טלפוניה וכד' לטעינה או לטובת שדרוגי גרסה וכו'. הניהול יתבצע באמצעות מנגנונים לניהול התקנים. כל רכיב שמתחבר יזוהה ויאושר מראש (White list).	ניתן ליישם באמצעות ביטול התקני USB באופן פיזי (נעילת פורט) או באופן לוגי על ידי מדיניות מערכת הפעלה - GPO.	2

זיהוי בקרה	כותרת	הבקרה	הסבר משלים	דוגמה לישום הבקרה	עומק בקרה*
12.25	מדיה נתיקה בסביבת הייצור	העברת קבצים ממדיה נתיקה למערכות הייצור תבוצע לאחר "הלבנת" הקבצים המועברים.	הארגון יטמיע מערך "הלבנת" קבצים ובדיקתם לעומק באמצעות כמה כלים טרם העברתם לסביבת הבקרים. לדוגמה, יכול להתבסס על טכנולוגיה מובנית או על תהליך עבודה לבדיקה ורישום מקדים: של מקור הקובץ (משתמש או אתר), תאריך ושעה, תיעוד וסיבה להבאת הקובץ, רישום מזהה ייחודי לכל הלבנה, יכולת תחקור אירועי העברת קבצים.	ניתן ליישם באמצעות הצטיידות בעמדות הלבנה ייעודיות, או, לחלופין, באמצעות הקמת עמדה ייעודית, הכוללת כמה מנועי סריקה שונים. באשר לתוכנות המגיעות מיצרנים יש לבצע בדיקה המבוססת על מנגנון לבדיקת חתימות.	2
12.26	יתירות סביבת הייצור	יתקיים מערך יתירות לרכיבים קריטיים בסביבת הייצור.	הארגון יטמיע מערכת יתירות של שרתים וחיישנים קריטיים לסביבות הבקרה לצורך המשכיות התהליך.	לצורך הקמת יתירות מומלץ להתייעץ בספק מערכת הבקרה.	2
12.27	גישה פיזית לסביבת הייצור	תוגבל גישה פיזית לפי צורך עסקי בלבד לסביבת הבקרים התעשייתיים וכן לצידוד התקשורת בסביבה זו.	הארגון יגביל גישה פיזית לארונות תקשורת, לרכזות ולעמדות ניהול של סביבת הבקרים. יש לשים לב, כי גם בעת התחברות לגיטימית (כגון לטובת ביצוע POC), תהליך חיבור רכיבים חיצוניים מתבצע בצורה בטוחה.	ניתן ליישם באמצעות הסבת חדרים ייעודיים לטובת ריכוזי תקשורת ושרתים ולבצע בקרת גישה באמצעות גישת תגים/זיהוי ביומטרי לסביבה זו. במטרה להבטיח מניעת חיבור לא מורשה לרשתות יש ליישם רכיב NAC.	2
12.28	הפרדת גישה לוגית	תוגבל גישה לוגית לפי צורך עסקי בלבד לסביבת הבקרים התעשייתיים וכן לצידוד התקשורת בסביבה זו.	הארגון יגביל גישת משתמשים ארגוניים אשר אין להם נגיעה עסקית למערך הבקרה וימנע גישתם לצידוד ורשתות אלו.		2

זיהוי בקרה	כותרת	הבקרה	הסבר משלים	דוגמה לישום הבקרה	עומק בקרה*
12.29	הפרדת גישה לוגית	תוגבל במידת האפשר גישה לוגית (פונקציונלית) למערכות הייצור, ובכללן ממשקי הבקרה, ממשקי הדגימה, ממשקי אדם-מכונה לפי תפקיד.	גישה למערכות הניהול תוגבל לפי פרופיל משתמש, בקר מערכת לא ישנה הגדרות ופרמטרים של מערכת, שינוי פרמטרים יבוצע על ידי משתמש ניהולי.	ניתן לוודא עם יצרן המערכת, כי יש אפשרות להשתמש בפרופילי משתמש שונים במערכת.	3
12.30	בדיקות חוסן	יש לבצע בדיקות אבטחת מידע וסייבר ובכללן מבדקי חדירה בסביבות הייצור ובממשקי הניהול.	הארגון יגדיר מתווה בדיקות כולל למגוון הרכיבים ברשת הבקרה, בדגש על בדיקות אבטחת מידע מקיפות לכלל הרכיבים, על מנת לשמור על רציפות התהליך העסקי. יש לשים לב, כי מתקיים בארגון תהליך עתי של מיפוי נתיבים, ערוצים ותרחישי תקיפה לצורך תיקוף ובחינת אפקטיביות הארכיטקטורה והתאמתה להתמודדות מפני פוגענים ברשת (מבוסס על מסמך ניהול סיכונים). הבדיקה תכלול, בין היתר, התייחסות להיבטי הלבנה, השחרה וקביעת צומתי סריקות מפני וירוסים וקודים עוינים, אשר עלולים להוות בעצמם ערוץ חדירה לארגון.	ניתן ליישם הן באמצעי בדיקת קונפיגורציה של הסביבות, הרצת סימולציות בזמן חלונות השבתה וכן ביצוע מבדקי חדירה לרשתות אלו במידת האפשר ו/או בזמן פעולות תחזוקה. חשוב לוודא, כי חוזי ההתקשרות עם הספקים יכללו דרישה לביצוע ביקורת ובקרה לפני הרכש, ואת הזכות של הלקוח לבצע ביקורת עצמאית במידת האפשר (לצד דרישה לעמידה של הספק בסטנדרטים מקובלים בתחום). יש לוודא טרם הבדיקה והרצת הכלים, כי לא עתידה להיות השפעה ופגיעה על ביצועים, תפקוד הרשת או בטיחות (לחלופין, ניתן לבדוד אזורים ולבצע באופן מבוקר). ניתן לנצל זמני השבתת יוזמות של סביבת הייצור לצורך בדיקות חוסן.	2

זיהוי בקרה	כותרת	הבקרה	הסבר משלים	דוגמה לישום הבקרה	עומק בקרה*
12.31	ניטור אבטחת מידע	יש להגדיר תרחישי ניטור ייחודיים לסביבת הייצור ולנטר אותם באמצעות מערך ניטור ארגוני.	הארגון יגדיר מגוון תרחישי ניטור ייעודיים לסביבת הבקרה לפי מתאר האיום וחשיבות המערכת לתהליך העסקי. יש לוודא, כי יותקנו מערכות ניטור ורישום פעילות על נכסים קריטיים, כגון שרתי ניהול/עמדות הנדסה.	ניטור ברשתות בקרה שונה מניטור מערכות רגילות מאחר שסף הרגישות נמוך יותר. כל חריגה מכמות תקשורת רגילה בין הבקרים לממשקי הניהול והחיישנים עלולה להצביע על אירוע סייבר פוטנציאלי מאחר שהפעילות בסביבות אלו רציפה ומונוטונית.	2
12.32	ניטור אבטחת מידע	הארגון יחזיק ביכולת ניטור לא תלויה ברשת התפעולית ו/או ברשת ה-IT (ניטור out of band).	ניטור זה בוחן שינוי במרחב הפיזי, אשר מהווה אינדיקציה שאינה תלויה בארכיטקטורה של הארגון ומהווה אנומליה, המצריכה בחינה של אנשי התפעול לסיבת החריגה.	ניתן למימוש, לדוגמה, באמצעות יכולת לקריאת ערכים (אנלוגיים ודיגיטליים) למדידת שינויים מהסנסורים והמפעילים (level 0) בתצורה מנותקת לחלוטין, שלא תלויה ברשת התפעולית (out of band) ולא מושפעת ממנה. שינויים אלו יכולים להתגלות באמצעות מדידת חשמל, לחץ, טמפרטורה וכד'.	4
12.33	הוצאת ציוד משימוש	בעת הוצאת ציוד משימוש, או הוצאתו לגורם חיצוני, יש להליכי מחיקה של קבצים ונתונים רגישים (כדוגמת קובצי לוגיקה, סיסמאות וכד')	בעת הוצאת ציוד משימוש, או הוצאתו לגורם חיצוני, יש לוודא תהליכי מחיקה של קבצים ונתונים רגישים (כדוגמת קובצי לוגיקה, סיסמאות וכד') ממערכות וציוד המחשב המועבר לגריטה. לרבות תהליכי גריטה בצמתים של תהליכי החלפה, שינוי סביבות וכד'.		2

זיהוי בקרה	כותרת	הבקרה	הסבר משלים	דוגמה לישום הבקרה	עומק בקרה*
12.34	מודיעין סייבר	יש לקבוע תהליך עתי סדור למעקב ולאיסוף מידע על חולשות ומתקפות בעולם ה-OT (מידע גלוי, פרסומים וכד').	תשומות מתאימות למעקב ייעודי אחר פרסומים מקצועיים לטובת הגנה על מערכות המחשוב ומערכות התפעול - הבטחת תהליך עתי לאיסוף וניתוח מידע רלוונטי ממקורות פנימיים וחיצוניים, לשמש כר להתקפות; פעולות שננקטו (פרסומים של ה-CERT, יצרניות, ספקים וכד'). מעקב זה יסייע לארגון לחזק את האבטחה ולהקשיח מערכות בהתאם לטובת מזעור משטח התקיפה.	יש לשים לב כי קיים מגננון של מודיעין גלוי רב בנושא, החל מאתרים לזיהוי ממשקים למערכות ERP אשר חשופות לאינטרנט ועד לפרסומים ללא עלות של גופי CERT, יצרני פתרונות אבטחה ועוד, אשר מפרטים ומדווחים על פגיעויות והתקפות ייעודיות לסביבות OT.	3
12.35	היערכות למצבי חירום	יש לתכנן וליישם תהליכי גיבוי והיערכות להתאוששות מאסון עבור הסביבה התפעולית.	יש להקים צוות IR ייעודי לטיפול באירועי סייבר בסביבות תפעוליות ותעשייתיות. צוות זה יכלול נציגים ממגוון דיסציפלינות ויוכשר בהתאם גם בתרגילים. במסגרת ההכשרה יש לסקור לצוות אירועי סייבר מהותיים. באם לא ניתן להעשיר צוות כזה, יש לשכור יכולות אלו מחברות ייעודיות המתמחות בכך.	תוגדר עמדת התאוששות מהירה, הכוללת עמדת הנדסה, כולל רישיונות ואפליקציות מותקנות על גבי מחשב נייד/נייח שלא מחובר לרשת (יש לבצע אחת לחצי שנה עדכונים מתאימים ולוודא כשירות תפעולית ומוכנות). יש לוודא נגישות מוגבלת לעמדה זו.	3
12.36	היערכות להתאוששות מאסון	יש לנקוט תשומות מתאימות ליצירת רציפות עסקית ומניעת סיכוני סייבר בתהליך סינכרון זמן.	תשומות לניתוח השפעות הדיוק הנדרש בין הרכיבים בתוך הרשת ובין רכיבים לרשתות אחרות והעולם. הבטחת קיומו של תהליך סנכרון שעון זמן ברשת ה-OT ואבטחת התהליך במימד האמינות והדיוק, יתירות מפצה ברשת.		4

6. «««« בילוגרפיה וחומר נלווה לקריאה

1. תורת ההגנה הארגונית גרסה 1.0

2. Clint E. Bodungen, Bryan Singer, (+3) Hacking Exposed, ICS Secrets and Solutions
3. Andrew Ginter, 13 ways through a firewall: What you do not know can hurt you 2013
4. Mariano Nunez, Cyber-attacks on ERP systems, An analysis of the current threat landscape, 2012
5. SP 800-82 R2 Guide to Industrial Control Systems (ICS) Security, May 2015
6. ANSI/ISA 62443 - Partially completed Document
7. NERC-CIP requirements for power utilities - Bulk Power Systems - BPS
8. ISO/IEC 27001-2013 and 27002, Cyber security for Information security management systems -ISMS
9. Andrew Ginter, Secure Operations Technology, Abterra 2018
10. Threat landscape for industrial automation systems, Kaspersky Labs, H2-2018
11. Blake Sobzak, Hackers force water utilities to sink or swim 03-2018
12. <https://ics-cert.us-cert.gov/Standards-and-References#conduct>





סייבר ישראל

מערך הסייבר הלאומי



119

INCD@cyber.gov.il

www.cyber.gov.il

חפשו אותנו